NPTEL / SWAYAM CERTIFICATION COURSE

ETHICAL HACKING: COMPREHENSIVE EXAM PREPARATION GUIDE

Complete Assignment Solutions, Verified Answers, and Pedagogical Explanations

Course Offered by: Indian Institute of Technology (IIT) Kharagpur
Course Instructor: Prof. Indranil Sengupta, Department of Computer Science and Engineering

About This Study Guide

Welcome to this comprehensive study guide prepared specifically for students preparing for the final proctored examination in Ethical Hacking. This document brings together all weekly assignment questions from Week 1 through Week 12, along with the foundational prerequisite refresher of Week 0, totaling 134 meticulously verified questions.

Every single question is accompanied by its complete options, the verified final true answer, and a comprehensive explanation crafted in a friendly, conversational academic tone. Mathematical problems are solved step by step from first principles, and each multiple-choice distractor is carefully dissected to explain not only why the correct answer is right, but also why alternative choices are incorrect. Use this guide to reinforce conceptual clarity, master practical commands, and excel in your certification examination.

Table of Contents & Curriculum Map

Week 0: Prerequisite Fundamentals & Network Security Refresher 2
Week 1: Introduction to Ethical Hacking, OSI Model, and Network Fundamentals 8
Week 2: IPv4 Fragmentation, TCP Flags, Subnetting, and Port Numbers 13
Week 3: Routing Protocols, Packet Delivery, Routing Tables, and IPv6 18
Week 4: Footprinting, Host Discovery, Nmap Scanning, and Port States 23
Week 5: Vulnerability Scanning, Password Cracking, Malware, and Switch Attacks 28
Week 6: Classical Cryptography, Attack Taxonomy, and Key Distribution 34
Week 7: Cryptographic Hashes, Digital Signatures, IPsec, and SSL/TLS 39
Week 8: Steganography, Biometrics, Denial of Service Attacks, and PGP 44
Week 9: Network Sniffing, Wireshark, Social Engineering, and ARP Spoofing 49
Week 10: Hardware Security, Side-Channel Attacks, PUFs, and Hardware Trojans 54
Week 11: Penetration Testing Frameworks, Web Attacks, SQL Injection, and XSS 60
Week 12: Host Discovery Sweeps, Advanced Nmap Scanning, and Port Topologies 66

Week 0: Prerequisite Fundamentals & Network Security Refresher

Module Overview & Key Learning Objectives:

Welcome to our introductory refresher module. Before we dive into advanced ethical hacking techniques, penetration testing methodologies, and defensive controls, we must ensure our foundational knowledge of networking, operating systems, and basic security concepts is crystal clear. Let us review these foundational concepts together.

Question 1 **What is ethical hacking?**

a. Unauthorized intrusion into a system or a network, and commit malicious activities such as privacy invasion, data theft, etc.
b. Systematically attempt to penetrate/intrude into a computer system/network on behalf of its owner and find out threats and vulnerabilities.

Final True Answer: b.

Professor's Detailed Explanation:

Ethical hacking, often referred to as white-hat hacking or penetration testing, involves legally and systematically attempting to penetrate a target computer system, application, or network infrastructure. The defining attribute here is explicit authorization. An ethical hacker operates strictly on behalf of the system owner and under documented rules of engagement. The core mission is defensive: discovering vulnerabilities, misconfigurations, and attack surfaces before adversaries can exploit them, thereby allowing the organization to remediate weaknesses proactively. Conversely, Option (a) defines malicious or black-hat hacking, where unauthorized access is gained with intent to compromise data integrity, steal confidential intellectual property, or cause operational disruption.

Question 2 **Which of the following application(s) is/are used to secure personal laptop/desktop?**

a. Antivirus
b. Virus
c. Malware
d. Firewall

Final True Answer: a., d.

Professor's Detailed Explanation:

To safeguard a personal workstation or laptop, a multi-layered host-based defense is essential. An Antivirus (Option a) provides endpoint security by scanning files against known malware signatures, heuristic behavioral patterns, and sandbox environments to detect, quarantine, and eliminate malicious executables. A Firewall (Option d), specifically a host-based personal firewall, monitors and controls incoming and outgoing network packets based on predefined security filtering rules. It blocks unauthorized connection attempts and restricts unauthorized software from opening listening sockets. In stark contrast, Virus (Option b) and Malware (Option c) are malicious software constructs that compromise, exploit, or damage systems, representing the exact threats we aim to mitigate.

Question 3 **What does LAN stand for?**

a. Long Area Network
b. Large Area Network
c. Local Area Network
d. Light Area Network

Final True Answer: c.

Professor's Detailed Explanation:

LAN stands for Local Area Network. In computer networking, networks are classified primarily by their geographical scope. A LAN interconnects computers, servers, printers, and IoT devices within a distinct, geographically limited area such as a residential home, academic laboratory, university department, or single office building. Local Area Networks typically boast high data transfer rates (ranging from 1 Gbps to 10 Gbps and beyond) and low latency due to shorter transmission distances, typically relying on Ethernet cabling or Wi-Fi (WLAN) protocols. Larger geographical networks include Metropolitan Area Networks (MANs) spanning entire cities, and Wide Area Networks (WANs) spanning countries or continents.

Question 4 **Which device is used to connect two different networks?**

a. Switch
b. Router
c. Hub
d. Repeater

Final True Answer: b.

Professor's Detailed Explanation:

A Router operates at Layer 3 (the Network Layer) of the OSI model and is specifically designed to forward packets between disparate, heterogeneous logical networks or IP subnets. Routers inspect the destination IP address of each incoming packet, evaluate their internal routing tables, and determine the optimal next-hop interface along the path to the destination. Conversely, a Network Switch (Option a) operates primarily at Layer 2 (Data Link Layer) and forwards Ethernet frames within the same local broadcast domain using MAC address tables. A Hub (Option c) is a legacy physical layer (Layer 1) multiport repeater that blindly broadcasts incoming electrical signals out of all other ports, creating a single shared collision domain. A Repeater (Option d) merely regenerates attenuated electrical signals along a physical cable run.

Question 5 **Which protocol is used to send emails?**

a. FTP
b. SMTP
c. HTTP
d. SNMP

Final True Answer: b.

Professor's Detailed Explanation:

The Simple Mail Transfer Protocol (SMTP), operating over TCP port 25 (or port 587 with modern submission authentication), is the internet standard protocol used to transmit outgoing email messages from a client email application to a mail server, as well as to relay messages between intermediate Mail Transfer Agents (MTAs). To read or retrieve incoming emails from a mailbox, clients use retrieval protocols such as Post Office Protocol version 3 (POP3) or Internet Message Access Protocol (IMAP). Looking at the distractors: FTP (File Transfer Protocol) transfers files; HTTP (Hypertext Transfer Protocol) delivers web resources; and SNMP (Simple Network Management Protocol) monitors and manages network hardware devices.

Question 6 **Which of the following Linux commands can be used to view network configuration?**

a. ipconfig
b. ifconfig
c. ls
d. cd
e. None of these

Final True Answer: b.

Professor's Detailed Explanation:

In traditional UNIX and Linux distributions, `ifconfig` (interface configuration) is the venerable command-line utility used to view, configure, and manage active network interfaces, displaying assigned IPv4/IPv6 addresses, subnet masks, broadcast addresses, and hardware MAC addresses. In contemporary Linux systems, the newer `ip addr` command from the `iproute2` suite has largely superseded it, but `ifconfig` remains widely used and tested. Option (a) `ipconfig` is the corresponding command in Microsoft Windows operating systems. Options (c) `ls` and (d) `cd` are filesystem navigation commands used to list directory contents and change current working directories, respectively.

Question 7 **How many layers are there in the OSI model?**

Numerical input (Integer)

Final True Answer: 7

Professor's Detailed Explanation:

The Open Systems Interconnection (OSI) reference model, standardized by the International Organization for Standardization (ISO), divides network communication into exactly 7 hierarchical layers. From bottom to top, these are: Layer 1: Physical Layer (transmits raw bit streams over physical media); Layer 2: Data Link Layer (frames data, provides physical MAC addressing and link error detection); Layer 3: Network Layer (handles logical IP addressing, routing, and path determination); Layer 4: Transport Layer (manages end-to-end communication, segmentation, flow control, and reliability via TCP/UDP); Layer 5: Session Layer (establishes, manages, and terminates sessions between applications); Layer 6: Presentation Layer (translates data formats, handles character encoding, compression, and encryption); and Layer 7: Application Layer (directly interfaces with user software applications like HTTP, FTP, and DNS). Remembering the classic mnemonic: 'Please Do Not Throw Sausage Pizza Away' makes recalling the order effortless.

Question 8 **Which of the following is/are transport layer protocol(s)?**

a. UDP
b. TCP
c. IP
d. Ethernet

Final True Answer: a., b.

Professor's Detailed Explanation:

The Transport Layer (Layer 4 of the OSI model, or the Host-to-Host layer in the TCP/IP stack) provides process-to-process communication services. Its two primary protocols are Transmission Control Protocol (TCP) and User Datagram Protocol (UDP). TCP is a connection-oriented protocol providing guaranteed delivery, sequence ordering, flow control, and congestion control. UDP is a connectionless, minimal-overhead protocol providing best-effort datagram delivery suited for real-time traffic like streaming audio/video and DNS queries. Regarding the distractors: Internet Protocol (IP) belongs to the Network Layer (Layer 3), and Ethernet operates across the Data Link (Layer 2) and Physical (Layer 1) layers.

Question 9 **Which layer of the OSI model is responsible for reliable data transmission?**

a. Data-Link
b. Network
c. Transport
d. Application

Final True Answer: c.

Professor's Detailed Explanation:

The Transport Layer (Layer 4) is specifically tasked with establishing true end-to-end reliability across a multi-hop network. It achieves this reliability primarily through the Transmission Control Protocol (TCP). TCP breaks application data into segments, assigns sequence numbers to track every byte transmitted, mandates receiver acknowledgment packets (ACKs), and dynamically initiates retransmissions whenever packet loss occurs. While the Data Link Layer (Layer 2) performs error detection over a single physical hop using frame check sequences (CRC), it does not ensure end-to-end connection recovery across diverse routed networks. The Network Layer (Layer 3) focuses on routing and delivers packets on a best-effort basis without guaranteeing delivery.

Question 10 **Which port number is normally used by HTTP?**

a. 80
b. 20
c. 21
d. 110

Final True Answer: a.

Professor's Detailed Explanation:

Hypertext Transfer Protocol (HTTP), the protocol governing unencrypted web traffic, by default listens and communicates on TCP port 80. Port 443 is assigned to HTTPS (HTTP Secure over TLS/SSL). Regarding the other options: TCP port 20 is used for FTP data transfer; TCP port 21 is used for FTP control commands; and TCP port 110 is utilized by Post Office Protocol version 3 (POP3) for retrieving incoming email messages.

Question 11 **Which of the following is/are not a valid IP address?**

a. 192.168.1.9
b. 255.102.3.25
c. 225.256.10.3
d. 192.168.296.1

Final True Answer: c., d.

Professor's Detailed Explanation:

An IPv4 address consists of 32 bits, divided evenly into four octets of 8 bits each, separated by periods in dotted-decimal notation. Because each octet contains exactly 8 bits, the numerical value of any single octet is strictly constrained to the range from 0 (binary 00000000) to 255 (binary 11111111). Examining the choices: Option (c) contains the value 256 in the second octet, which exceeds the mathematical maximum of 255 and cannot be represented in 8 bits. Option (d) contains 296 in the third octet, which is similarly invalid. Both Option (a) and Option (b) have all four octets strictly between 0 and 255, making them syntactically valid.

Question 12 **In IPv6, the number of bits used in IP address is:**

Numerical input (Integer)

Final True Answer: 128

Professor's Detailed Explanation:

Internet Protocol version 6 (IPv6) was engineered to resolve the imminent exhaustion of the 32-bit IPv4 address space. IPv6 uses a 128-bit address architecture, providing an astronomically large address pool of 2 to the power of 128 (approximately 3.4 times 10 to the 38th power unique addresses). IPv6 addresses are expressed as eight groups of four hexadecimal digits separated by colons (for example, 2001:0db8:85a3:0000:0000:8a2e:0370:7334). This massive expansion accommodates every device, sensor, and host imaginable worldwide, eliminating the necessity of Network Address Translation (NAT) for address conservation.

Question 13 **Which of the following command(s) can be used to check the reachability of one system from another?**

a. ping
b. ls
c. mkdir
d. None of these

Final True Answer: a.

Professor's Detailed Explanation:

The `ping` utility is the standard diagnostic tool across all operating systems for verifying network reachability between two hosts. It operates by generating and transmitting Internet Control Message Protocol (ICMP) Echo Request packets (Type 8) to the target destination IP address. If the target host is reachable and its firewall does not drop ICMP traffic, it responds by returning an ICMP Echo Reply packet (Type 0). The utility calculates the round-trip latency and packet loss percentage. In contrast, `ls` lists directory contents and `mkdir` creates new directories in Unix/Linux file systems.

Question 14 **Which of the following networks is used to cover small area like a room/building?**

a. LAN
b. WAN
c. MAN
d. None of these

Final True Answer: a.

Professor's Detailed Explanation:

A Local Area Network (LAN) is expressly designed to connect computing equipment across a restricted, small geographical perimeter, such as a single room, residential home, university computer lab, or office building. A Metropolitan Area Network (MAN) covers a broader municipal area such as a city or large university campus. A Wide Area Network (WAN), exemplified by the global Internet, spans vast geographic distances across provinces, countries, and continents, interconnecting disparate LANs via telecommunications carriers.

Week 1: Introduction to Ethical Hacking, OSI Model, and Network Fundamentals

Module Overview & Key Learning Objectives:

In this foundational week of the course, we explore the core tenets of information security: the CIA Triad, penetration testing methodologies (black box, white box, gray box), packet switching versus circuit switching, packet delay mathematics, and the fundamental structure of IP and TCP headers.

Question 1 **Which of the following belong to the CIA Triad in information security?**

a. Confidentiality
b. Authentication
c. Availability
d. Accountability
e. Integrity
f. Authorization

Final True Answer: a., c., e.

Professor's Detailed Explanation:

The CIA Triad constitutes the universally accepted bedrock model for designing and evaluating information security controls. It consists of three primary objectives: Confidentiality (Option a), ensuring that information is concealed from unauthorized individuals, entities, or processes; Integrity (Option e), guaranteeing that data has not been modified, tampered with, or corrupted in an unauthorized manner during storage or transit; and Availability (Option c), ensuring that systems, networks, and applications remain accessible and operational for authorized users whenever needed. Although Authentication (verifying identity), Authorization (granting specific permissions), and Accountability (auditing and tracking actions) are essential supporting security services, they are auxiliary mechanisms that serve the broader goals of the CIA Triad.

Question 2 **Which of the following penetration testing models provides the tester with no prior information about the target network?**

a. White box model
b. Black box model
c. Gray box model
d. Blue box model

Final True Answer: b.

Professor's Detailed Explanation:

In a Black Box penetration testing engagement, the ethical hacker simulates an external adversary. The tester is provided with zero inside knowledge regarding the target organization's internal network architecture, server IP addresses, operating system types, or application source code. The tester must perform initial reconnaissance, footprinting, and enumeration entirely from scratch. In contrast, in a White Box test (Option a), the tester receives comprehensive documentation, network diagrams, configuration files, and full source code access. In a Gray Box test (Option c), the tester is granted partial insider access, such as standard employee login credentials or an internal IP address range. 'Blue box' (Option d) is not a standardized penetration testing model (blue teaming refers to the internal defensive operations team).

Question 3 **Which of the following statement(s) is/are true for packet-switched networks?**

a. Bandwidth is dedicated for the entire duration of a session.
b. Multiple connections can share the same communication link.
c. Delay is always constant regardless of network load.
d. It requires end-to-end circuit setup before data transfer.
e. Data is divided into smaller packets before transmission.
f. It guarantees zero packet loss under all conditions.

Final True Answer: b., e.

Professor's Detailed Explanation:

Packet-switched networks, which form the operational basis of the modern Internet via the TCP/IP protocol suite, operate by breaking high-level application data into discrete, manageable units called packets (Option e). Each packet contains source and destination headers and can be dynamically routed through the network. Multiple independent communication flows can concurrently share the same physical transmission link through statistical multiplexing (Option b), maximizing bandwidth utilization efficiency. In contrast, Options (a), (c), and (d) describe circuit-switched networks (such as traditional landline telephone systems), where a dedicated physical circuit is established prior to data transfer, providing constant delay and dedicated bandwidth. Packet switching cannot guarantee zero packet loss (Option f) because intermediate router queues experience congestion when arrival rates exceed transmission capacity, leading to buffer drops.

Question 4 **Which OSI layer is primarily responsible for framing, MAC addressing, and error detection over a physical link?**

a. Physical layer
b. Data link layer
c. Network layer
d. Transport layer
e. Session layer

Final True Answer: b.

Professor's Detailed Explanation:

The Data Link Layer (Layer 2 of the OSI reference model) is specifically tasked with node-to-node data transfer across a single physical communication link. It encapsulates network-layer IP packets into discrete Layer 2 units called frames, prefixes them with hardware source and destination MAC (Media Access Control) addresses, and appends a Frame Check Sequence (FCS) using a Cyclic Redundancy Check (CRC) to detect bit-level transmission errors introduced by physical noise. The Physical Layer (Layer 1) deals purely with raw bits and electrical/optical signaling; the Network Layer (Layer 3) handles end-to-end logical IP addressing and inter-network routing; and the Transport Layer (Layer 4) manages process-level flow control and connection reliability.

Question 5 **A 1500-byte packet is sent over a 100 Kbps point-to-point link whose propagation delay is 8 msec. The packet will reach the destination after ____ msec. (Assume 1K = 1000)**

Numerical input (Range: 120 to 130; exact value: 128)

Final True Answer: 128

Professor's Detailed Explanation:

Let us solve this step by step using the fundamental principles of network latency. The total delay required for a packet to reach its destination across a single point-to-point link is the sum of the transmission delay and the propagation delay: Total Delay = Transmission Delay + Propagation Delay.

First, calculate the Transmission Delay, which is the time required to push all the packet's bits onto the physical transmission medium: Transmission Delay = Packet Size (in bits) / Bandwidth (in bits per second).
Given: Packet size = 1500 bytes = 1500 * 8 bits = 12000 bits.
Bandwidth = 100 Kbps = 100 * 1000 bps = 100000 bps (since 1K = 1000 as explicitly specified in the problem).
Transmission Delay = 12000 bits / 100000 bps = 0.12 seconds = 120 milliseconds.

Second, add the Propagation Delay, which is the time taken for a bit to physically travel through the transmission medium from source to destination: Propagation Delay = 8 milliseconds.

Finally, compute the total elapsed time: Total Delay = 120 msec + 8 msec = 128 milliseconds. The answer falls cleanly within the accepted range of 120 to 130.

Question 6 **What is the primary purpose of an IP address in a network?**

a. It identifies the physical hardware manufacturer of a device.
b. It uniquely identifies a host or interface on a network.
c. It specifies the number of open ports on a system.
d. It determines the encryption algorithm used by a host.

Final True Answer: b.

Professor's Detailed Explanation:

An Internet Protocol (IP) address serves as a logical numerical label assigned to every network interface connected to an IP network. Its primary function is two-fold: providing host identification (uniquely pinpointing a specific network node or interface) and providing logical location addressing (structuring addresses into network and host portions to enable hierarchical, multi-hop routing across global networks). Option (a) describes the Organizationally Unique Identifier (OUI), which is the first 24 bits of a Layer 2 MAC address. Option (c) confuses IP addresses with Layer 4 port addresses, and Option (d) is unrelated to basic network addressing.

Question 7 **_____ is the minimum size (in bytes) of a TCP header without options.**

Numerical input (Integer)

Final True Answer: 20

Professor's Detailed Explanation:

The base header of the Transmission Control Protocol (TCP) consists of 5 mandatory 32-bit (4-byte) words, establishing a fixed minimum size of 20 bytes (160 bits). These 20 bytes comprise: Source Port (16 bits), Destination Port (16 bits), Sequence Number (32 bits), Acknowledgment Number (32 bits), Data Offset (4 bits) + Reserved (3 bits) + Control Flags (9 bits) + Window Size (16 bits), and Checksum (16 bits) + Urgent Pointer (16 bits). If optional TCP fields are included (such as Maximum Segment Size, Window Scaling, or Timestamps), the header can expand in 4-byte increments up to a maximum of 60 bytes, governed by the 4-bit Data Offset field (whose maximum value is 15 * 4 = 60 bytes).

Question 8 **Which IP header field is decremented at every router hop and is primarily used to prevent packets from looping indefinitely in a network?**

a. Header checksum
b. Fragment offset
c. Time to Live (TTL)
d. HLEN
e. Identification

Final True Answer: c.

Professor's Detailed Explanation:

The Time to Live (TTL) field in the IPv4 header (renamed 'Hop Limit' in IPv6) is an 8-bit counter designed to eliminate rogue packets caught in routing loops. When a packet is originated, the sender sets TTL to an initial value (commonly 64, 128, or 255). Every router that handles and forwards the packet decrements the TTL value by at least 1. If the TTL value reaches 0 before the packet reaches its final destination, the router immediately drops the packet and generates an ICMP Time Exceeded error message (Type 11, Code 0) back to the source IP address. This crucial mechanism also forms the operational foundation of the `traceroute` diagnostic tool.

Question 9 **If the IP header is 224 bits long, what will be the value (in decimal) of the HLEN field?**

Numerical input (Integer)

Final True Answer: 7

Professor's Detailed Explanation:

Let us break down how the IPv4 Header Length (HLEN) field is encoded. The HLEN field is a 4-bit field in the IPv4 header that specifies the total length of the header in units of 32-bit (4-byte) words. This scaling factor of 4 is necessary because a 4-bit binary field can only hold values from 0 to 15, while an IP header can range from 20 to 60 bytes.

First, convert the header length from bits to bytes: Header Length in bytes = 224 bits / 8 bits per byte = 28 bytes.

Second, determine how many 4-byte (32-bit) words are contained in 28 bytes: HLEN value = 28 bytes / 4 bytes per word = 7.

Therefore, the 4-bit HLEN field contains the binary pattern `0111`, which represents 7 in decimal.

Question 10 **____ bits are used to represent a MAC address.**

Numerical input (Integer)

Final True Answer: 48

Professor's Detailed Explanation:

A standard Media Access Control (MAC) address, formally known as an Extended Unique Identifier 48 (EUI-48), is 48 bits (6 bytes) in length. It is universally represented as twelve hexadecimal digits, typically separated into pairs by colons or hyphens (for example, `00:0C:29:4F:8E:35`). The first 24 bits represent the Organizationally Unique Identifier (OUI) assigned to the network interface manufacturer by the IEEE Registration Authority. The remaining 24 bits represent the unique station identifier assigned by that manufacturer. MAC addresses operate at Layer 2 (Data Link Layer) to uniquely identify network interface cards on the local physical network segment.

Week 2: IPv4 Fragmentation, TCP Flags, Subnetting, and Port Numbers

Module Overview & Key Learning Objectives:

This week dives deeply into the mechanics of the Internet Protocol and Transmission Control Protocol. We analyze IPv4 fragmentation flags (DF, MF, Offset), TCP control flags (SYN, ACK, FIN, RST, URG), CIDR subnetting and broadcast addressing, private address ranges (RFC 1918), and header sizing calculations.

Question 1 **An IP packet arrives with the first eight bits as 0100 0101. How many bytes are there in the OPTIONS field?**

Numerical input (Integer)

Final True Answer: 0

Professor's Detailed Explanation:

The very first byte (8 bits) of an IPv4 packet header is divided into two distinct 4-bit fields: the Version field (bits 0 to 3) and the Header Length (HLEN) field (bits 4 to 7).

Here, the first 8 bits are given as `0100 0101`:
- The first 4 bits are `0100`, which equals 4 in decimal. This signifies Internet Protocol Version 4 (IPv4).
- The next 4 bits are `0101`, which equals 5 in decimal. This represents the HLEN value.

Since HLEN specifies the total header length in 32-bit (4-byte) words, the total header length is: Total Header Length = 5 * 4 bytes = 20 bytes.

Because the standard, base IPv4 header with no options is exactly 20 bytes long, there is zero room allocated for options. Hence, the OPTIONS field contains exactly 0 bytes.

Question 2 **Which of the following is/are true for TCP header flag bits?**

a. SYN=1, ACK=0 indicates a connection request.
b. SYN=1, ACK=1 indicates connection confirmation.
c. FIN flag is used to reject a connection.
d. RST flag is used to gracefully terminate a connection.
e. URG flag indicates urgent data in the segment.

Final True Answer: a., b., e.

Professor's Detailed Explanation:

Let us analyze the role of each TCP control flag:
- Option (a) is true: In the classic TCP three-way handshake, the initiating client sends a segment with `SYN=1, ACK=0` to request the establishment of a new connection and synchronize initial sequence numbers.
- Option (b) is true: The server acknowledges the request and synchronizes its own sequence number by responding with `SYN=1, ACK=1`.
- Option (e) is true: The URG flag, when set to 1, indicates that the segment contains urgent out-of-band data, instructing the receiver to evaluate the Urgent Pointer field to find the last byte of urgent data.
- Option (c) is false: The FIN (Finish) flag is used for graceful, orderly termination of a connection once all data has been transmitted, not for rejecting connections.
- Option (d) is false: The RST (Reset) flag is used for abrupt, ungraceful termination or immediate rejection of an invalid connection attempt (such as when a packet arrives at a closed port). Graceful termination is the role of FIN.

Question 3 **Which of the following represents a valid broadcast address for its respective subnet (as specified)?**

a. 10.255.255.255 for network 10.0.0.0/8
b. 10.20.0.0 for network 10.20.0.0/16
c. 192.168.5.255 for network 192.168.5.0/24
d. 172.16.255.0 for network 172.16.0.0/16
e. 192.168.5.0 for network 192.168.5.0/24

Final True Answer: a., c.

Professor's Detailed Explanation:

In IPv4 addressing, the directed broadcast address for any subnet is formed by setting all host bits (bits not covered by the network prefix) to binary 1s.
- For `10.0.0.0/8`: The prefix length is 8 bits (the first octet). The remaining 24 bits are host bits. Setting all 24 host bits to 1 produces `10.255.255.255`. This is a valid broadcast address (Option a).
- For `192.168.5.0/24`: The prefix length is 24 bits (the first three octets). The remaining 8 bits are host bits. Setting all 8 host bits to 1 yields `192.168.5.255`. This is a valid broadcast address (Option c).
- Options (b) and (e) represent the network addresses (where all host bits are 0), not broadcast addresses.
- In Option (d), for `172.16.0.0/16`, the host portion spans the last 16 bits. Setting all host bits to 1 yields `172.16.255.255`. Thus `172.16.255.0` is merely an intermediate host address, not the broadcast address.

Question 4 **An IP packet arrives at the final destination with D flag = 0, M flag = 0, and offset = 5. Which of the following is true?**

a. The packet has not been fragmented.
b. The packet is the first fragment.
c. The packet is the last fragment of a fragmented packet.
d. The packet will be dropped due to invalid flags.

Final True Answer: c.

Professor's Detailed Explanation:

Let us examine the three fragmentation control fields in the IPv4 header:
1. The Don't Fragment (D) flag: Here D = 0, meaning fragmentation was permitted.
2. The More Fragments (M) flag: When M = 1, more fragments follow. When M = 0, no more fragments follow this packet.
3. The Fragment Offset field: This indicates the relative position of the fragment's data in the original unfragmented datagram, measured in units of 8-byte blocks.

Here, offset = 5, which means 5 * 8 = 40 bytes of data preceded this fragment. Since the offset is greater than 0, this packet is definitely not the first fragment (first fragments always have offset = 0) and it is not an unfragmented packet (unfragmented packets have both M = 0 and offset = 0). Because M = 0, no subsequent fragments exist. Combining offset > 0 and M = 0 proves conclusively that this packet is the last fragment of a fragmented datagram.

Question 5 **Which of the following IP address ranges are reserved for private use?**

a. 10.0.0.0 to 10.255.255.255
b. 100.64.0.0 to 100.127.255.255
c. 172.16.0.0 to 172.31.255.255
d. 192.168.0.0 to 192.168.255.255
e. 169.254.0.0 to 169.254.255.255
f. 224.0.0.0 to 239.255.255.255

Final True Answer: a., c., d.

Professor's Detailed Explanation:

RFC 1918 defines three private IPv4 address blocks designated for internal corporate, institutional, and home local area networks. These addresses are not globally routable on the public Internet:
1. 24-bit block (Class A): `10.0.0.0/8` spanning `10.0.0.0` to `10.255.255.255` (Option a).
2. 20-bit block (Class B): `172.16.0.0/12` spanning `172.16.0.0` to `172.31.255.255` (Option c).
3. 16-bit block (Class C): `192.168.0.0/16` spanning `192.168.0.0` to `192.168.255.255` (Option d).

Let us review what the distractors represent: Option (b) `100.64.0.0/10` is reserved for Carrier-Grade NAT (RFC 6598); Option (e) `169.254.0.0/16` is the link-local / APIPA range (RFC 3927) used when DHCP fails; and Option (f) `224.0.0.0` to `239.255.255.255` is Class D multicast space.

Question 6 **Which of the following well-known port number(s) is/are correctly matched with their corresponding service?**

a. HTTP - 80
b. FTP - 21
c. SSH - 25
d. DNS - 23
e. Telnet - 53
f. SMTP - 22

Final True Answer: a., b.

Professor's Detailed Explanation:

Well-known ports (ports 0 to 1023) are standardized by IANA for core Internet services:
- HTTP (Hypertext Transfer Protocol) operates on port 80 (Option a is correct).
- FTP (File Transfer Protocol command channel) operates on port 21 (Option b is correct).

Now, observe how the remaining pairs have been intentionally swapped by the examiner:
- SSH (Secure Shell) actually operates on port 22, whereas port 25 is SMTP (Simple Mail Transfer Protocol).
- DNS (Domain Name System) actually operates on port 53, whereas port 23 is Telnet (unencrypted terminal emulation). Thus, only Options (a) and (b) are correctly matched.

Question 7 **What is the subnet mask corresponding to CIDR notation /26?**

a. 255.255.255.0
b. 255.255.255.128
c. 255.255.255.192
d. 255.255.255.224
e. 255.255.255.240

Final True Answer: c.

Professor's Detailed Explanation:

In Classless Inter-Domain Routing (CIDR) notation, the prefix `/26` indicates that the first 26 bits of the 32-bit subnet mask are set to binary 1s, and the remaining 6 bits (32 - 26 = 6) are set to binary 0s.

Let us write this out in binary by octets:
- Octet 1: `11111111` = 255
- Octet 2: `11111111` = 255
- Octet 3: `11111111` = 255
- Octet 4: `11000000`

Converting the fourth octet to decimal:
`1*128 + 1*64 + 0*32 + 0*16 + 0*8 + 0*4 + 0*2 + 0*1 = 128 + 64 = 192`.

Putting all four octets together yields `255.255.255.192`. This provides 2^(6) = 64 total IP addresses per subnet, of which 62 are assignable to host interfaces.

Question 8 **Which of the following statement(s) is/are true about IPv4 fragmentation and the 'Don't Fragment' (DF) bit?**

a. If DF = 1 and packet size exceeds MTU, the packet is dropped and an error is generated.
b. If DF = 1, the router fragments the packet regardless of size.
c. If DF = 0, fragmentation is allowed if necessary.
d. DF bit is part of the Fragment Offset field.
e. DF = 1 guarantees the packet will always reach its destination.

Final True Answer: a., c.

Professor's Detailed Explanation:

The Don't Fragment (DF) bit is the second bit in the 3-bit Flags field of the IPv4 header:
- When DF = 1 (Option a), the sender explicitly forbids intermediate routers from fragmenting the packet. If the packet arrives at a router whose next-hop outgoing link has a Maximum Transmission Unit (MTU) smaller than the packet size, the router has no choice: it must drop the packet and transmit an ICMP error message back to the sender ('Destination Unreachable: Fragmentation Needed and DF Set', Type 3, Code 4). This mechanism enables Path MTU Discovery (PMTUD).
- When DF = 0 (Option c), routers along the path are permitted to fragment the packet into smaller chunks whenever required to fit within link MTUs.
- Option (d) is false because the DF bit resides in the 3-bit Flags field, which precedes the 13-bit Fragment Offset field. Option (e) is false because setting DF = 1 increases the likelihood of drops if PMTUD fails or ICMP is blocked.

Question 9 **An IP packet has HLEN = 12 and TOTAL LENGTH = 900 bytes. The number of data bytes in the packet will be ____**

Numerical input (Integer)

Final True Answer: 852

Professor's Detailed Explanation:

Let us solve this calculation systematically:
1. The HLEN field expresses the total header length in 32-bit (4-byte) words. Given HLEN = 12, the actual IP header size in bytes is: Header Length = 12 * 4 bytes = 48 bytes.
2. The Total Length field in the IPv4 header encompasses the entirety of the packet, meaning it includes both the IP header and the encapsulated data payload: Total Length = Header Length + Data Length.
3. We are given Total Length = 900 bytes. Rearranging to find the payload data bytes: Data Length = Total Length - Header Length = 900 bytes - 48 bytes = 852 bytes.

Thus, the packet carries exactly 852 bytes of payload data.

Question 10 **____ is the size (in bytes) of a UDP header.**

Numerical input (Integer)

Final True Answer: 8

Professor's Detailed Explanation:

The User Datagram Protocol (UDP) header is engineered for simplicity and minimal overhead. Unlike TCP, UDP does not support options, sequence numbers, or windowing. It consists of exactly four fields, each 16 bits (2 bytes) wide:
1. Source Port (2 bytes)
2. Destination Port (2 bytes)
3. Length (2 bytes, specifying the total length of UDP header plus payload)
4. Checksum (2 bytes, for optional error checking over header and data)

Total UDP header size = 2 + 2 + 2 + 2 = 8 bytes (64 bits). This fixed 8-byte overhead makes UDP exceptionally fast for lightweight transactions and real-time communications.

Week 3: Routing Protocols, Packet Delivery, Routing Tables, and IPv6

Module Overview & Key Learning Objectives:

This week explores network-layer routing fundamentals. Topics include connectionless IP routing, direct versus indirect packet delivery, routing table flag conventions (U, G, H, D, M), routing protocols (RIP, OSPF, BGP), default routing, IPv6 architecture, and CIDR host address calculations.

Question 1 **Which of the following statement(s) is/are true regarding connectionless routing used by the IP protocol?**

a. Each packet is treated as an independent unit for routing decisions.
b. A fixed path is established before any packet is transmitted.
c. Different packets between the same source and destination may follow different paths.
d. IP protocol uses connection-oriented routing.

Final True Answer: a., c.

Professor's Detailed Explanation:

The Internet Protocol (IP) implements a connectionless, datagram-based packet switching service at Layer 3. In this model, no prior signaling or circuit setup occurs before transmission. Each packet (datagram) carries full destination addressing information and is treated by intermediate routers as an entirely independent entity when making forwarding decisions (Option a). Because network topologies and link costs dynamically shift, or load-balancing mechanisms activate, successive packets belonging to the very same application session may be routed along completely different physical paths to the destination (Option c). This dynamic routing can cause packets to arrive out of order, which is subsequently reordered by Layer 4 TCP. In contrast, Options (b) and (d) describe connection-oriented routing (such as virtual circuit networks like X.25 or ATM).

Question 2 **Which of the following statement(s) is/are false regarding direct and indirect packet delivery?**

a. Direct delivery occurs when the destination host and deliverer are on the same physical network.
b. Indirect delivery occurs when the destination host is not on the same network as the deliverer.
c. In direct delivery, packets always pass through at least one router.
d. In indirect delivery, the packet is routed hop by hop until it reaches a router on the destination's network.
e. Direct delivery can occur between the last router and the destination host.

Final True Answer: c.

Professor's Detailed Explanation:

In IP internetworking, packet delivery is categorized into direct and indirect delivery:
- Direct delivery occurs when the transmitting node (either the source host or the final router along the path) and the destination host share the exact same physical network (same broadcast domain). In direct delivery, the sender maps the destination IP to its hardware MAC address using ARP and transmits the frame directly across the local link. Crucially, direct delivery does NOT pass through any intermediate router. Therefore, Option (c) is completely false and is the correct answer to this 'select the false statement' question.
- Indirect delivery occurs when the destination resides on a remote network. The sender must forward the packet to an intermediate router (default gateway), which routes it hop by hop across networks until it reaches the final router, which then executes direct delivery to the destination host.

Question 3 **Which routing table flag indicates that a route is specific to a single host rather than an entire network?**

a. U
b. G
c. H
d. D
e. M

Final True Answer: c.

Professor's Detailed Explanation:

Standard Unix/Linux and router routing tables maintain a Flags column that reveals the operational status of each route entry:
- Flag `U` (Up) indicates that the route is active and operational.
- Flag `G` (Gateway) indicates that the route points to an indirect gateway (an intermediate router) rather than a directly attached interface.
- Flag `H` (Host) indicates that the route is a host-specific route, meaning the destination address is a complete 32-bit IP address representing a single individual machine, rather than a network address with a subnet mask. This directly confirms Option (c).
- Flag `D` (Dynamic) indicates that the route was dynamically installed by an ICMP redirect message.
- Flag `M` (Modified) indicates that the route was modified dynamically by an ICMP redirect.

Question 4 **In the OSPF routing protocol, which type of packet is used to determine whether a neighboring router is active?**

a. Link State Update
b. Link State Request
c. Hello packet
d. Link State Acknowledgement
e. TCP SYN packet

Final True Answer: c.

Professor's Detailed Explanation:

Open Shortest Path First (OSPF) is an interior gateway link-state routing protocol. OSPF routers periodically send Hello packets (OSPF Packet Type 1) across all enabled interfaces. The primary purpose of Hello packets is to discover adjacent neighbors on the link, establish bidirectional adjacency, elect the Designated Router (DR) and Backup Designated Router (BDR) on multi-access networks, and act as a heartbeat/keepalive mechanism to verify that neighboring routers remain active and reachable. If a neighbor fails to return a Hello packet within a designated Dead Interval (typically four times the Hello interval), it is declared down, triggering link-state re-convergence.

Question 5 **Which type of address should be used when a packet needs to be delivered to every host within a specific network?**

a. Unicast address
b. Broadcast address
c. Anycast address
d. None of these

Final True Answer: b.

Professor's Detailed Explanation:

A Broadcast address is explicitly designated for one-to-all communication within a given network or subnet. When a packet is transmitted to the broadcast address (such as the local broadcast `255.255.255.255` or a directed broadcast like `192.168.1.255`), every active host on that physical link receives, decodes, and processes the frame. In contrast: a Unicast address identifies a single, unique interface for one-to-one communication; and an Anycast address is assigned to multiple interfaces (typically across different geographical locations), where packets are routed to the nearest topological node.

Question 6 **Which of the following statement(s) is/are false regarding routing protocols?**

a. RIP uses distance vector routing and can suffer from the count-to-infinity problem.
b. OSPF is a link-state routing protocol.
c. BGP is used for routing within a single autonomous system.
d. OSPF uses Dijkstra's algorithm to compute shortest paths.
e. RIP is typically used for routing between different autonomous systems.

Final True Answer: e.

Professor's Detailed Explanation:

Let us scrutinize the statements:
- Statement (a) is true: The Routing Information Protocol (RIP) is a classic distance-vector protocol based on the Bellman-Ford algorithm, which can suffer from slow convergence and count-to-infinity.
- Statement (b) is true: OSPF is indeed an open standard link-state protocol.
- Statement (d) is true: OSPF nodes construct a complete network topology database and execute Dijkstra's Shortest Path First (SPF) algorithm to calculate optimal routes.
- Statement (e) is definitively false: RIP is strictly an Interior Gateway Protocol (IGP) designed for small local networks with a maximum hop count of 15. It is never used for inter-autonomous system routing. Border Gateway Protocol (BGP) is the de facto Exterior Gateway Protocol (EGP) used between autonomous systems on the global Internet. (Note: Statement c refers to internal BGP or iBGP, but Option e is unequivocally false).

Question 7 **What is the address used to represent the default route in a routing table (in IPv4)?**

a. 127.0.0.1
b. 255.255.255.255
c. 0.0.0.0
d. 192.0.0.1
e. None of these

Final True Answer: c.

Professor's Detailed Explanation:

In IPv4 networking, the default route (often called the 'gateway of last resort') is represented by the address `0.0.0.0` with a subnet mask of `0.0.0.0` (written in CIDR notation as `0.0.0.0/0`). When a router inspects its routing table using the longest-prefix match rule, if no specific network, subnet, or host route matches the destination IP of an incoming packet, the packet matches this catch-all default route and is forwarded to the designated default gateway. Reviewing the other choices: `127.0.0.1` is the loopback address; and `255.255.255.255` is the limited broadcast address.

Question 8 **Which of the following statement(s) is/are false regarding IPv6?**

a. IPv6 supports address classes similar to IPv4 (Class A, B, C).
b. IPv6 addresses are typically represented in hexadecimal, separated by colons.
c. IPv6 eliminates the need for fragmentation by intermediate routers.
d. The base header size of IPv6 is variable, ranging from 20 to 60 bytes.

Final True Answer: a., d.

Professor's Detailed Explanation:

Let us examine the architecture of IPv6:
- Statement (a) is false: IPv6 completely discards the legacy classful addressing scheme (Class A, B, C) of early IPv4. It uses classless, prefix-based addressing from the ground up.
- Statement (b) is true: IPv6 addresses are 128 bits long and formatted as eight groups of four hexadecimal digits separated by colons.
- Statement (c) is true: A major architectural improvement in IPv6 is that intermediate routers never fragment packets. Fragmentation is exclusively performed by the originating sending host using Path MTU Discovery and an optional Fragment Extension Header.
- Statement (d) is false: Unlike IPv4 (whose header length is variable between 20 and 60 bytes), the IPv6 base header is strictly fixed at exactly 40 bytes. Any optional metadata is chained using modular Extension Headers.
Thus, statements (a) and (d) are both false.

Question 9 **In IPv6 base header, ____ bits are used for Hop Limit?**

Numerical input (Integer)

Final True Answer: 8

Professor's Detailed Explanation:

In the fixed 40-byte IPv6 base header, the field corresponding to the IPv4 Time to Live (TTL) is named the Hop Limit. It is an 8-bit integer field. Every forwarding router decrements the Hop Limit by 1. If the value drops to 0, the packet is discarded and an ICMPv6 Time Exceeded message is returned to the source. Because it is an 8-bit field, its value ranges from 0 to 255.

Question 10 **An organization is assigned 172.20.64.0/20 network block. ____ number of valid host addresses are available in this block.**

Numerical input (Integer)

Final True Answer: 4094

Professor's Detailed Explanation:

Let us compute the assignable host capacity for the CIDR block `172.20.64.0/20`:
1. The total number of bits in an IPv4 address is 32.
2. Given a `/20` network prefix, the number of bits remaining for host addressing is: Host Bits (h) = 32 - 20 = 12 bits.
3. The total number of IP addresses contained in a 12-bit host space is: 2^h = 2^(12) = 4096 addresses.
4. In any standard IPv4 subnet, two special addresses cannot be assigned to individual host network interfaces: the Network Address (where all 12 host bits are 0) and the Directed Broadcast Address (where all 12 host bits are 1).
5. Subtracting these two reserved addresses gives: Valid Host Addresses = 2^h - 2 = 4096 - 2 = 4094 valid host addresses.

Week 4: Footprinting, Host Discovery, Nmap Scanning, and Port States

Module Overview & Key Learning Objectives:

This week focuses on practical reconnaissance and scanning methodologies. We examine hypervisor lab setups, Whois intelligence gathering, ICMP echo sweeps, Nmap TCP SYN (stealth) scans, VirtualBox NAT networking behavior, OS and version detection flags, and service identification.

Question 1 **What is the primary purpose of a Hypervisor in a penetration testing lab setup?**

a. It encrypts all network traffic between virtual machines.
b. It allows creation and management of multiple virtual machines on a single physical system.
c. It is a hack-proof security layer for the host OS.
d. It automatically patches vulnerabilities on guest machines.
e. None of these.

Final True Answer: b.

Professor's Detailed Explanation:

In an ethical hacking or penetration testing laboratory, a Hypervisor (such as Oracle VirtualBox, VMware Workstation, or Proxmox) is a virtualization layer that abstracts physical hardware, enabling multiple isolated guest virtual machines (for example, Kali Linux attack machines, vulnerable targets like Metasploitable, and Windows domain controllers) to run concurrently on a single physical computer (Option b). It provides isolated virtual networks (Host-Only, Internal, NAT) and instant snapshot capabilities, allowing researchers to practice exploits, detonate malware, and capture traffic safely without endangering production physical networks. Hypervisors do not automatically encrypt traffic, nor are they immune to security flaws (hypervisor escape vulnerabilities exist).

Question 2 **Which of the following information CANNOT typically be retrieved using a Whois lookup?**

a. Domain registration details
b. Name servers
c. Registrant contact information
d. Historical snapshots of the website
e. Domain expiration date

Final True Answer: d.

Professor's Detailed Explanation:

A Whois lookup queries regional domain registrars (RIRs and ICANN databases) to retrieve ownership, administrative, and technical metadata about an active domain name. Standard Whois records include the domain registrar name, creation and expiration dates, authoritative DNS name servers, and registrant/technical contact details (subject to modern privacy redactions). Whois does NOT archive or store the historical visual appearance, files, or snapshots of a website. That capability is provided by web archives such as the Wayback Machine (archive.org).

Question 3 **How does host discovery using an ICMP Echo sweep work?**

a. An ICMP type-8 request is sent, and an ICMP type-0 reply confirms the host is alive.
b. A TCP SYN packet is sent, and an ACK confirms the host is alive.
c. It broadcasts ARP requests to identify all hosts on the segment.
d. None of these.

Final True Answer: a.

Professor's Detailed Explanation:

An ICMP Echo sweep systematically probes a range of IP addresses to determine which hosts are online. It sends an ICMP Echo Request (Type 8, Code 0) to each target IP. When an active host receives this request and has no firewall blocking ICMP, its operating system kernel returns an ICMP Echo Reply (Type 0, Code 0). Receiving a Type 0 response confirms that the target system is powered on, connected to the network, and responsive (Option a). Option (b) describes a TCP-based ping sweep, and Option (c) describes an ARP sweep (which is highly effective on local subnets but non-routable across routers).

Question 4 **Which NMAP option(s) can be used to perform a TCP-based host discovery sweep?**

a. -PE
b. -PS
c. -PA
d. -PU
e. -PM

Final True Answer: b., c.

Professor's Detailed Explanation:

Nmap provides a suite of ping options for host discovery during the reconnaissance phase:
- `-PS` (TCP SYN Ping, Option b): Sends an empty TCP packet with the SYN flag set (by default to port 80). If the port is open, the target responds with SYN-ACK; if closed, it responds with RST. In either case, the receipt of any response proves the host is online.
- `-PA` (TCP ACK Ping, Option c): Sends a TCP packet with the ACK flag set (by default to port 80). Because no connection exists, compliant operating systems return an RST packet, confirming the host is up. This is useful for evading stateless firewalls that permit established traffic.
- Reviewing the distractors: `-PE` is ICMP Echo ping; `-PU` is UDP ping; and `-PM` is ICMP Address Mask ping. Only `-PS` and `-PA` are TCP-based discovery options.

Question 5 **During the TCP three-way handshake, what type of message does the client send first to initiate the connection?**

a. ACK
b. SYN
c. SYN-ACK
d. RST
e. FIN

Final True Answer: b.

Professor's Detailed Explanation:

The fundamental TCP three-way handshake establishes a reliable full-duplex byte stream between client and server:
1. Step 1: The client initiates the handshake by transmitting a segment with the SYN (Synchronize) control flag set and an initial sequence number (ISN_c). Option (b) is correct.
2. Step 2: The server responds with a segment having both SYN and ACK flags set (`SYN-ACK`), acknowledging the client's sequence number and providing its own initial sequence number (ISN_s).
3. Step 3: The client replies with an `ACK` segment, confirming receipt of the server's SYN. At this point, the connection enters the ESTABLISHED state.

Question 6 **In a TCP SYN (stealth) scan, which packet response(s) indicates that a port is open or closed, respectively?**

a. SYN-ACK received indicates the port is open.
b. RST received indicates the port is closed.
c. ACK received indicates the port is open.
d. FIN received indicates the port is open.

Final True Answer: a., b.

Professor's Detailed Explanation:

A TCP SYN scan (Nmap option `-sS`), also known as a half-open or stealth scan, operates without completing the full TCP three-way handshake:
- The scanner sends a raw TCP segment with the SYN flag to the target port.
- If the target port is OPEN (listening), the operating system replies with a `SYN-ACK` packet (Option a). The scanner immediately sends an `RST` packet to tear down the connection before an application session is established, avoiding full connection logs.
- If the target port is CLOSED, the target kernel immediately replies with an `RST` (Reset) packet (Option b).
- If the port is FILTERED by a firewall, either no response is received (timeout) or an ICMP unreachable error is returned. Therefore, both (a) and (b) are accurate statements.

Question 7 **Which of the following statement(s) is/are true regarding the default networking mode (NAT) in Oracle VirtualBox?**

a. It assigns a unique public IP address to each virtual machine.
b. It assigns the same private/virtual IP address to guest operating systems.
c. Virtual machines using this mode can access the internet.
d. It assigns the host system's IP address directly to guest machines.
e. Virtual machines using NAT mode are directly reachable from outside the host by default.

Final True Answer: b., c.

Professor's Detailed Explanation:

In Oracle VirtualBox, the default Network Address Translation (NAT) mode functions as follows:
- VirtualBox acts as an internal router and DHCP server for the VM. By default, every independent VM configured with standard NAT is assigned the exact same private IP address: `10.0.2.15` (with the gateway at `10.0.2.2`). Option (b) is true.
- Outgoing packets from the guest VM are translated by the hypervisor using the host system's IP address, allowing guest VMs full outbound access to the Internet (Option c is true).
- Option (e) is false because, by design, machines on the external physical network or even other VMs cannot directly initiate inbound connections to a NAT VM without explicit port forwarding rules. For direct inter-VM communication, Bridged, Host-Only, or NAT Network modes are preferred.

Question 8 **Which of the following NMAP option(s) can be used for OS and/or service version detection?**

a. -sn
b. -O
c. -sV
d. -Pn
e. -A

Final True Answer: b., c., e.

Professor's Detailed Explanation:

Let us review the operational flags in Nmap:
- `-O` (Option b): Enables remote Operating System detection using TCP/IP stack fingerprinting (analyzing ISN predictability, TCP options, IP ID sampling, and window size behavior).
- `-sV` (Option c): Enables service Version detection, actively interrogating open ports with specific probes to determine the exact daemon application name and version (for example, Apache httpd 2.4.41 or OpenSSH 8.2p1).
- `-A` (Option e): Enables Aggressive scan mode, which combines OS detection (`-O`), version scanning (`-sV`), script scanning (`-sC`), and traceroute (` - traceroute`).
- In contrast: `-sn` performs ping sweeps without port scanning, and `-Pn` skips host discovery.

Question 9 **If ports 80 and 443 are found open on a target system, what can be reasonably inferred?**

a. The target is very likely running SSH services.
b. The target is very likely hosting a website (HTTP/HTTPS).
c. The target is running a mail server.
d. The target is running a DNS resolver.
e. None of these.

Final True Answer: b.

Professor's Detailed Explanation:

Port 80 is the standard port for Hypertext Transfer Protocol (HTTP), and port 443 is the standard port for HTTP Secure (HTTPS). Discovering both ports open and listening on a target system indicates that the host is operating a web server daemon (such as Apache, Nginx, or Microsoft IIS) hosting website or web application services. A mail server would expose ports 25, 110, 143, or 993/995; an SSH server operates on port 22; and a DNS resolver listens on port 53.

Question 10 **If the - reason option is used along with a SYN scan. Which of the following is/are correct if reason field shows 'syn-ack'?**

a. The port is open because NMAP received a SYN-ACK response from the target.
b. The port is closed, and no evidence is available.
c. The target sent an RST packet in response.
d. None of these.

Final True Answer: a.

Professor's Detailed Explanation:

Nmap's ` - reason` flag is a powerful diagnostic switch that instructs Nmap to display the precise network evidence that determined each port's classified state. During a TCP SYN scan (`-sS`), if a target port responds to Nmap's SYN probe with a `SYN-ACK` packet, Nmap marks the port as `open` and prints `syn-ack` in the reason column (Option a). If the target had responded with an `RST` packet, the port would be classified as `closed` with the reason `conn-refused` or `reset`.

Week 5: Vulnerability Scanning, Password Cracking, Malware, and Switch Attacks

Module Overview & Key Learning Objectives:

In Week 5, we transition into vulnerability assessment, password auditing, and Layer 2 attacks. Key subjects include Nmap Scripting Engine (NSE) execution flags, distinguishing vulnerability scanners from brute-force password tools, password attack taxonomy, malware classification, CAM table MAC flooding, SMB OS enumeration, and combinatorial brute-force calculations.

Question 1 **Which of the following NMAP option(s) can trigger execution of NMAP scripts?**

a. -A
b. -sC
c. -Pn
d. - script=default
e. -sn

Final True Answer: a., b., d.

Professor's Detailed Explanation:

The Nmap Scripting Engine (NSE) extends Nmap's core network probing capabilities by executing Lua scripts for advanced network discovery, vulnerability detection, and exploit verification. There are multiple ways to invoke default scripts:
- `-sC` (Option b): Explicitly runs all scripts categorized under the 'default' group.
- ` - script=default` (Option d): Is functionally identical to `-sC`, invoking the default script suite.
- `-A` (Option a): Enables aggressive scan mode, which bundles OS detection (`-O`), service version scanning (`-sV`), script scanning (`-sC`), and traceroute together.
- Distractors: `-Pn` disables host discovery (treating hosts as online), and `-sn` runs a ping sweep without any port or script scanning.

Question 2 **Which of the following tool(s)/software CANNOT be used for vulnerability scanning?**

a. Nessus
b. Hydra
c. Nexpose
d. Crunch
e. NMAP

Final True Answer: b., d.

Professor's Detailed Explanation:

Vulnerability scanners are automated software suites designed to audit network hosts, operating systems, and services against databases of known CVEs (Common Vulnerabilities and Exposures), misconfigurations, and outdated patch levels. Nessus (Option a) and Nexpose (Option c) are dedicated, industry-standard commercial vulnerability scanners. Nmap (Option e) performs vulnerability scanning via its NSE vulnerability scripts (such as `vuln` category scripts).

In contrast:
- Hydra (Option b) is a high-speed, multi-threaded network login brute-forcing tool designed to test authentication credentials across protocols like SSH, FTP, and Telnet.
- Crunch (Option d) is a wordlist generator utility that produces custom character combinations for password cracking dictionaries.
Neither Hydra nor Crunch possesses vulnerability scanning logic or CVE assessment engines, making them the correct answers to this 'CANNOT' question.

Question 3 **Which of the following is NOT considered a common password cracking approach?**

a. Dictionary attack
b. Brute-force attack
c. Rule-based attack
d. Packet sniffing
e. Shoulder surfing

Final True Answer: d.

Professor's Detailed Explanation:

Let us understand the technical distinction between password cracking and password harvesting. Password cracking refers to computational algorithms applied to crack an unknown plaintext password from its mathematical cryptographic hash, or actively guessing credentials against an authentication interface. Standard cracking approaches include: dictionary attacks (testing precompiled lists of common words), brute-force attacks (exhaustively trying every permutation of characters), and rule-based attacks (applying mangling rules like capitalizing letters or substituting numbers for vowels).

In contrast, Packet Sniffing (Option d) is a passive network interception technique. It captures network frames as they traverse an unencrypted medium (such as HTTP, FTP, or Telnet). It does not computationally 'crack' anything; it simply reads cleartext credentials directly off the wire as they pass by. Shoulder surfing (Option e) is a physical social engineering method, but packet sniffing is the classic distractor representing passive network surveillance.

Question 4 **Which protocol in TCP/IP is connectionless and does not provide reliability?**

a. TCP
b. UDP
c. FTP
d. TELNET

Final True Answer: b.

Professor's Detailed Explanation:

User Datagram Protocol (UDP) is the quintessential connectionless transport-layer protocol in the Internet protocol suite. Unlike TCP, UDP transmits datagrams without establishing a handshake, maintains no connection state, generates no sequence numbers, demands no acknowledgment packets, and provides no built-in retransmission mechanism for dropped packets. It offers best-effort delivery with minimum latency, making it the preferred choice for real-time voice, video streaming, DNS queries, and gaming. TCP (Option a) is fully connection-oriented and reliable. FTP (Option c) and Telnet (Option d) are application-layer protocols that run on top of reliable TCP.

Question 5 **Which tool is primarily used to generate custom wordlists for use in dictionary-based password attacks?**

a. Hydra
b. Nessus
c. Crunch
d. Wireshark
e. Hashcat

Final True Answer: c.

Professor's Detailed Explanation:

Crunch is a specialized command-line utility in penetration testing (standard in Kali Linux) designed to generate customized wordlists. By specifying minimum and maximum string lengths, character sets (alphabetic, numeric, symbols), and custom formatting patterns, Crunch computes and outputs all possible permutations into a dictionary file or pipes them directly into a cracking tool. Reviewing the other tools: Hydra is an online network login brute-forcer; Nessus is a vulnerability scanner; Wireshark is a packet analyzer; and Hashcat is a GPU-accelerated offline password hash recovery tool.

Question 6 **Which of the following statement(s) is/are false regarding malware?**

a. All malware types are capable of self-replication.
b. Malware can grant partial or full control of a system to an attacker.
c. Malware can be delivered through file sharing or fake/pirated software.
d. Malware can modify, corrupt, or delete data on infected systems.
e. None of these.

Final True Answer: a.

Professor's Detailed Explanation:

Malware (malicious software) is an umbrella classification encompassing many distinct categories of harmful code. Crucially, self-replication is a property unique to Computer Viruses (which attach to clean host executables and propagate when the host file runs) and Computer Worms (which autonomously exploit network vulnerabilities to spread from machine to machine across networks without human intervention). Many major categories of malware, including Trojan Horses, Spyware, Ransomware, Adware, and Rootkits, do NOT self-replicate. Trojans, for instance, rely entirely on social engineering to trick victims into executing them. Therefore, asserting that 'all malware types are capable of self-replication' is completely false, making Option (a) the correct answer.

Question 7 **In a MAC flooding attack, what is the primary goal of overwhelming a switch's CAM table?**

a. To crash the switch permanently.
b. To force the switch to behave like a hub, broadcasting traffic to all ports.
c. To increase the switch's available memory.
d. To disable the switch's power supply.
e. None of these.

Final True Answer: b.

Professor's Detailed Explanation:

A network switch relies on a Content Addressable Memory (CAM) table to store dynamic mappings between physical switch ports and the MAC addresses of connected devices. This enables the switch to forward unicast traffic exclusively to the specific intended recipient port, preventing other connected devices from eavesdropping. In a MAC Flooding attack (using tools like `macof`), an adversary blasts tens of thousands of bogus, randomly generated source MAC addresses at the switch within seconds. When the CAM table fills to capacity, the switch experiences 'fail-open' behavior: unable to store new MACs or look up destinations, it defaults to flooding all incoming unicast frames out of every single port on the switch, behaving like an unswitched hub. This allows the attacker's network card (in promiscuous mode) to capture and sniff sensitive packets intended for other workstations (Option b).

Question 8 **Which of the following NMAP script(s) is/are used specifically for identifying the operating system of an SMB-enabled target?**

a. smb-os-discovery
b. smb-brute
c. http-os-brute
d. smb-enum-users
e. ssh-brute

Final True Answer: a.

Professor's Detailed Explanation:

The Nmap Scripting Engine provides `smb-os-discovery` (Option a) within the discovery category. It connects to the Server Message Block (SMB) service on port 139 or 445 and queries native OS dialect negotiation messages. The target system returns precise operating system name, service pack level, NetBIOS computer name, workgroup/domain name, and system clock time, providing exceptionally high-fidelity OS identification without requiring a full generic stack fingerprint. Among the other scripts: `smb-brute` brute-forces SMB credentials; `smb-enum-users` enumerates user accounts; and `ssh-brute` attempts SSH password guessing.

Question 9 **An attacker is using hydra to perform a dictionary attack on an SSH service, testing a wordlist of 5000 passwords against 4 different usernames. The maximum number of login attempts that could be made is _____**

Numerical input (Integer)

Final True Answer: 20000

Professor's Detailed Explanation:

Let us compute the total possible authentication attempts. In an online dictionary attack using Hydra, each target username must be tested against every candidate password contained within the provided dictionary file:
Total Login Attempts = (Number of Usernames) * (Number of Passwords in Wordlist).
Given:
Number of usernames = 4.
Number of passwords = 5000.
Total Maximum Login Attempts = 4 * 5000 = 20000 attempts.

Assuming the server does not enforce account lockout policies or IP rate-limiting, Hydra will attempt up to 20,000 distinct login handshakes before exhausting its queue.

Question 10 **If a symmetric-style brute-force password cracker needs to try all combinations of a 4-character password using only lowercase letters (26 possible characters per position), how many total password combinations are possible?**

Numerical input (Integer)

Final True Answer: 456976

Professor's Detailed Explanation:

Let us solve this using standard combinatorial counting principles. We are tasked with finding the total search space for a fixed-length password:
Password length (k) = 4 positions.
Character set size (N) = 26 lowercase English letters (a through z).

Since each of the 4 positions can independently take any of the 26 possible characters, the total number of permutations is given by: Total Combinations = N^k = 26^4.

Calculating step by step:
26^1 = 26
26^2 = 676
26^3 = 17576
26^4 = 456976.

Therefore, a brute-force password cracker must evaluate exactly 456,976 combinations to guarantee testing every possible 4-letter lowercase password.

Week 6: Classical Cryptography, Attack Taxonomy, and Key Distribution

Module Overview & Key Learning Objectives:

Week 6 immerses us in cryptography, the mathematical science of protecting information. We analyze the classic security attack taxonomy (Interruption, Interception, Modification, Fabrication), classical substitution and mono-alphabetic ciphers, hashing properties, public-key encryption mechanics, DES block sizing, and key distribution scaling in symmetric versus asymmetric cryptosystems.

Question 1 **Which of the following attack types involves an attacker pretending to be a legitimate entity to gain unauthorized access?**

a. Replay attack
b. Masquerade attack
c. Modification attack
d. Denial of service attack
e. Traffic analysis

Final True Answer: b.

Professor's Detailed Explanation:

A Masquerade attack (Option b), also known as identity spoofing or impersonation, occurs when an unauthorized entity assumes the identity of an authorized principal (such as spoofing an IP address, forging user credentials, or fabricating an administrative session token) to deceive an authentication system into granting access rights. Let us distinguish this from the distractors: a Replay attack captures valid authentication packets and retransmits them later; a Modification attack alters the contents of messages in transit; a Denial of Service attack prevents legitimate access; and Traffic Analysis is a passive attack that inspects packet lengths, timing, and frequencies to infer communication metadata.

Question 2 **Encrypt the plaintext 'SECURE' using a substitution cipher where each letter is replaced by its k-th next letter, assuming alphabets wrap around (Z followed by A) and k = 3.**

a. VHFXUH
b. VFEXRU
c. UHFXVH
d. VHFXRV
e. None of these

Final True Answer: a.

Professor's Detailed Explanation:

This is the classic Caesar Cipher with a shift key of k = 3. The transformation formula for each letter is: C = (P + 3) mod 26, where A = 0, B = 1, ..., Z = 25.

Let us map each character of the plaintext 'SECURE' systematically:
1. 'S' is letter 18. (18 + 3) mod 26 = 21 -> 'V'
2. 'E' is letter 4. (4 + 3) mod 26 = 7 -> 'H'
3. 'C' is letter 2. (2 + 3) mod 26 = 5 -> 'F'
4. 'U' is letter 20. (20 + 3) mod 26 = 23 -> 'X'
5. 'R' is letter 17. (17 + 3) mod 26 = 20 -> 'U'
6. 'E' is letter 4. (4 + 3) mod 26 = 7 -> 'H'

Concatenating the resulting ciphertext letters yields 'VHFXUH'. Option (a) is the exact match.

Question 3 **Consider a mono-alphabetic cipher with the key mapping: Plain: (A B C D E F G H I J K L M N O P Q R S T U V W X Y Z) mapped to Cipher: (Q W E R T Y U I O P A S D F G H J K L Z X C V B N M). What will be the encrypted form of the message 'CODE'?**

a. EGRT
b. EGDT
c. EODT
d. EGDR
e. None of these

Final True Answer: a.

Professor's Detailed Explanation:

In a mono-alphabetic substitution cipher, a fixed, bijective one-to-one mapping exists between the 26 plaintext letters and a permuted 26-letter cipher alphabet. Let us look up each letter of 'CODE' directly in the provided key mapping:
- Plaintext 'C' is the 3rd letter of the alphabet. The 3rd letter of the cipher key is 'E'. Thus, C -> E.
- Plaintext 'O' is the 15th letter of the alphabet. Counting to the 15th position in the cipher key (Q W E R T Y U I O P A S D F G ...): the 15th letter is 'G'. Thus, O -> G.
- Plaintext 'D' is the 4th letter of the alphabet. The 4th letter of the cipher key is 'R'. Thus, D -> R.
- Plaintext 'E' is the 5th letter of the alphabet. The 5th letter of the cipher key is 'T'. Thus, E -> T.

Assembling the substituted characters gives 'EGRT', perfectly matching Option (a).

Question 4 **Which of the following statement(s) is/are false regarding hashing algorithms used for message integrity?**

a. A good hash function should be resistant to collisions.
b. The same input will always produce the same hash output.
c. A hash function can be reversed to retrieve the original message.
d. Even a small change in input should produce a significantly different hash output.

Final True Answer: c.

Professor's Detailed Explanation:

Cryptographic hash functions (such as SHA-256 and SHA-3) are strictly one-way mathematical functions (preimage resistant). Given an arbitrary input message x, computing the hash value h = H(x) is computationally trivial; however, given only the hash value h, it is computationally infeasible to invert the function to recover the original message x. Therefore, asserting that a hash function 'can be reversed to retrieve the original message' is completely false, making Option (c) the correct response.

All other statements represent fundamental requirements of cryptographic hashing: Option (a) describes collision resistance (hard to find any x != y such that H(x) = H(y)); Option (b) describes determinism; and Option (d) describes the avalanche effect.

Question 5 **Decrypt the ciphertext 'KHOOR' which was encrypted using a substitution cipher with a shift of k = 3 (each letter replaced by its k-th next letter during encryption, the alphabets wrap around).**

a. HELLO
b. WORLD
c. HELPS
d. HFLLO
e. None of these

Final True Answer: a.

Professor's Detailed Explanation:

To decrypt a Caesar cipher encrypted with a forward shift of k = 3, we apply the inverse transformation: shifting each ciphertext letter backward by 3 positions: P = (C - 3) mod 26.

Applying this decryption formula to each letter of 'KHOOR':
1. 'K' is letter 10. (10 - 3) mod 26 = 7 -> 'H'
2. 'H' is letter 7. (7 - 3) mod 26 = 4 -> 'E'
3. 'O' is letter 14. (14 - 3) mod 26 = 11 -> 'L'
4. 'O' is letter 14. (14 - 3) mod 26 = 11 -> 'L'
5. 'R' is letter 17. (17 - 3) mod 26 = 14 -> 'O'

Reconstructing the decrypted characters gives the well-known word 'HELLO', which matches Option (a).

Question 6 **A DoS attack that makes a system or service inaccessible to legitimate users falls under which category of security attack?**

a. Interruption
b. Interception
c. Modification
d. Fabrication
e. Replay

Final True Answer: a.

Professor's Detailed Explanation:

In computer security theory, security attacks are classified into four fundamental categories relative to the CIA Triad:
1. Interruption (Option a): An asset of the system is destroyed, disabled, or made unavailable. Denial of Service (DoS) attacks, cutting physical fiber cables, or disabling server processes directly violate Availability, classifying them as Interruption attacks.
2. Interception: An unauthorized party gains access to an asset (e.g., wiretapping or packet sniffing), violating Confidentiality.
3. Modification: An unauthorized party tampers with or alters data (e.g., altering a database record or man-in-the-middle message modification), violating Integrity.
4. Fabrication: An unauthorized party inserts counterfeit objects or messages into the system (e.g., adding unauthorized records or sending forged emails), violating Authenticity.

Question 7 **For encryption using public-key cryptography, if sender A wants to send a confidential message to receiver B, which key is used to encrypt the message?**

a. A's private key
b. A's public key
c. B's public key
d. B's private key

Final True Answer: c.

Professor's Detailed Explanation:

In asymmetric (public-key) cryptography, every participant possesses a mathematically linked key pair: a public key (openly distributed to the world) and a private key (kept strictly secret by the owner). The fundamental cryptographic rule for confidentiality is: encrypt with the recipient's public key, decrypt with the recipient's private key.

When sender A wishes to transmit a confidential message to receiver B, A encrypts the plaintext using B's Public Key (Option c). Because B's Public Key is asymmetric, the resulting ciphertext can only be decrypted by the corresponding unique mathematical inverse, which is B's Private Key. Even sender A cannot decrypt the ciphertext once generated. In contrast, if A encrypted the message with A's private key (Option a), anyone possessing A's public key could decrypt it; that is used for digital signatures (authenticity and non-repudiation), not confidentiality.

Question 8 **_____ is the block size (in bits) used for plaintext blocks in the Data Encryption Standard (DES) algorithm.**

Numerical input (Integer)

Final True Answer: 64

Professor's Detailed Explanation:

The Data Encryption Standard (DES) is a symmetric-key block cipher developed by IBM and standardized by NIST (FIPS PUB 46). DES operates on plaintext blocks of exactly 64 bits (8 bytes) at a time, transforming each 64-bit plaintext input into a 64-bit ciphertext output through 16 rounds of a Feistel network. While the key length provided to the algorithm is nominally 64 bits, 8 of those bits are discarded as parity check bits, leaving an effective cryptographic key length of 56 bits. However, the block size itself is strictly 64 bits.

Question 9 **150 parties want to exchange messages securely using a public key encryption technique like RSA. How many distinct key values will be required?**

Numerical input (Integer)

Final True Answer: 300

Professor's Detailed Explanation:

Let us examine the scaling efficiency of public-key (asymmetric) cryptography. In an asymmetric cryptosystem like RSA, each participating entity requires exactly one key pair: one public key and one private key. Therefore, each party requires 2 distinct key values.

For N distinct communicating parties:
Total Keys Required = 2 * N.
Given N = 150 parties:
Total Keys Required = 2 * 150 = 300 distinct key values.

Notice the immense scalability of asymmetric cryptography: the number of keys scales linearly O(N), rather than quadratically O(N^2) as in symmetric encryption. Each party publishes their 1 public key and securely stores their 1 private key, allowing all 150 parties to communicate securely.

Question 10 **40 parties want to exchange messages securely using a symmetric key encryption algorithm. How many distinct keys will be required?**

Numerical input (Integer)

Final True Answer: 780

Professor's Detailed Explanation:

In symmetric-key cryptography, a single shared secret key must be mutually shared between every distinct communicating pair of participants. If any two parties need to communicate without any other party being able to eavesdrop, they must share an exclusive, unique secret key.

Mathematically, the total number of unique pairwise connections among N participants is the combination formula 'N choose 2':
Total Keys = N * (N - 1) / 2.
Given N = 40 parties:
Total Keys = 40 * (40 - 1) / 2 = 40 * 39 / 2 = 20 * 39 = 780 distinct secret keys.

This calculation dramatically underscores the classic 'key distribution problem' of symmetric cryptography: as the user population grows, the required number of keys explodes quadratically O(N^2).

Week 7: Cryptographic Hashes, Digital Signatures, IPsec, and SSL/TLS

Module Overview & Key Learning Objectives:

In Week 7, we examine modern cryptographic building blocks: the fixed-length output property of hash functions, block and digest sizes (DES, MD5, SHA-512), SSL/TLS architecture, collision resistance definitions, digital signature verification mechanics, non-repudiation, keyed hashes (HMAC), and IPsec modes (Transport vs Tunnel).

Question 1 **A message M is fed to a hash function to generate hash value H = HASH(M). Which of the following statement(s) is/are true?**

a. The number of bits in H is typically much smaller than the number of bits in M.
b. The number of bits in H and M are always exactly equal.
c. Hashing produces a fixed-length output regardless of input size.
d. The output length of a hash function grows proportionally with the input length.

Final True Answer: a., c.

Professor's Detailed Explanation:

A cryptographic hash function takes an arbitrary, variable-length input message M and computes a compact, fixed-length bit string known as a message digest or hash value H (Option c). Whether the input message is a single character or a 100-gigabyte database backup, the hash output length remains strictly constant (for example, exactly 256 bits in SHA-256). In practical applications, the message M comprises thousands or millions of bits, whereas the hash digest H is compact (typically 128, 256, or 512 bits), meaning the bit length of H is typically vastly smaller than that of M (Option a). Options (b) and (d) are false because hash functions do not grow proportionally with input size.

Question 2 **Which of the following statement(s) is/are true?**

a. The block size of DES is 64 bits.
b. The key size of DES is 128 bits.
c. The hash digest size of MD5 is 128 bits.
d. SHA-256 produces a 512-bit digest.
e. Triple DES uses a fixed 512-bit key.

Final True Answer: a., c.

Professor's Detailed Explanation:

Let us verify each cryptographic specification:
- Statement (a) is true: The Data Encryption Standard (DES) operates on 64-bit plaintext blocks.
- Statement (c) is true: The Message Digest 5 (MD5) algorithm produces a fixed-size 128-bit (16-byte) hash digest.
- Statement (b) is false: The key size of DES is 56 bits (not 128 bits; AES commonly uses 128 bits).
- Statement (d) is false: SHA-256, as its name indicates, produces a 256-bit hash digest (512 bits is produced by SHA-512).
- Statement (e) is false: Triple DES (3DES) uses three 56-bit keys, resulting in an effective key length of 112 bits (two-key 3DES) or 168 bits (three-key 3DES), never 512 bits. Thus, only (a) and (c) are true.

Question 3 **Which of the following statement(s) is/are true regarding SSL/TLS protocols?**

a. HTTPS relies on SSL/TLS to secure HTTP communication.
b. SSL/TLS guarantees faster data transmission compared to plain HTTP.
c. TLS operates at the physical layer of the network stack.
d. The SSL Record Protocol guarantees non-repudiation of the sender.

Final True Answer: a.

Professor's Detailed Explanation:

Secure Sockets Layer (SSL) and its modern standardized successor, Transport Layer Security (TLS), provide cryptographic security over computer networks. HTTPS (HTTP Secure) is simply standard HTTP layered directly on top of an established SSL/TLS session, providing mutual authentication via digital certificates, data confidentiality via symmetric session encryption, and data integrity via Message Authentication Codes (Option a). Examining the distractors: SSL/TLS introduces computational overhead and round-trip handshake latency, making it slightly slower than plain unencrypted HTTP, not faster (Option b); TLS operates at the Transport/Application boundary (Layer 4/Layer 7), not the physical layer (Option c); and the SSL Record Protocol provides confidentiality and integrity, but does not provide non-repudiation (Option d).

Question 4 **Which of the following statement(s) is/are true regarding collision resistance in hash functions?**

a. It is a weaker requirement than second preimage resistance.
b. It should be computationally difficult to find any two distinct messages producing the same hash.
c. Collision resistance guarantees encryption confidentiality.
d. Collision resistance is trivial to achieve for any hash function design.
e. Collision resistance applies only to keyed hash functions (MACs).

Final True Answer: b.

Professor's Detailed Explanation:

Collision resistance is a fundamental property of cryptographic hash functions. Formally, a hash function H is collision-resistant if it is computationally infeasible to find ANY pair of distinct messages x and y (where x != y) such that H(x) = H(y) (Option b). Due to the Birthday Paradox, finding collisions requires approximately 2^(n/2) operations for an n-bit hash, which is computationally easier than second preimage resistance (where the attacker is given a fixed x and must find an alternate y producing the same hash, requiring approximately 2^n operations). Hence, collision resistance is a strictly STRONGER and harder requirement to fulfill than second preimage resistance, making Option (a) false. Hash functions do not provide confidentiality (Option c), and collision resistance is difficult to achieve (Option d).

Question 5 **Which of the following statement(s) is/are true regarding digital signature verification?**

a. The verifier uses the signer's public key to verify a signature.
b. The verifier uses the signer's private key to verify a signature.
c. Successful verification confirms the message has not been altered and was signed by the claimed signer.
d. Verification requires the signer to be online and actively participating.

Final True Answer: a., c.

Professor's Detailed Explanation:

Digital signatures rely on asymmetric public-key cryptography to provide authentication, data integrity, and non-repudiation:
- The signer creates the signature by computing the hash of the message and encrypting that hash using their own Private Key.
- The verifier validates the signature by decrypting the signature using the signer's openly available Public Key (Option a) to recover the original hash, and independently recalculating the hash of the received message. If the two hash digests match, it provides mathematical proof that the message has not been altered in transit and that it originated from the owner of the corresponding private key (Option c).
- Option (b) is false because the private key must never be shared with verifiers. Option (d) is false because signature verification is completely asynchronous: anyone can verify a signed document offline at any time.

Question 6 **Which property of digital signatures ensures that the original signer cannot later deny having signed a message?**

a. Confidentiality
b. Integrity
c. Non-repudiation
d. Availability
e. Authentication

Final True Answer: c.

Professor's Detailed Explanation:

Non-repudiation (Option c) is the legal and technical assurance that a party to a communication or transaction cannot successfully dispute the validity or authorship of their signature or statement. Because a digital signature can only be generated using the signer's strictly confidential private key, a valid signature serves as irrefutable cryptographic proof of origin. Confidentiality prevents unauthorized reading; Integrity ensures the message was not modified; Availability ensures access; and Authentication proves identity, but Non-repudiation specifically provides accountability against subsequent denial.

Question 7 **Which of the following statements is false regarding keyed vs unkeyed hash functions?**

a. An unkeyed hash function can be used to verify data integrity when the hash value is obtained from a trusted source.
b. A keyed hash function requires a secret key as part of its computation.
c. An unkeyed hash function inherently provides authenticity.
d. HMAC can be used to provide both integrity and a degree of authentication.

Final True Answer: c.

Professor's Detailed Explanation:

Let us understand why Option (c) is false and therefore the correct answer:
- An unkeyed hash function (like standalone SHA-256) takes only the message M as input. Anyone in possession of the message can compute the hash. If an active man-in-the-middle attacker modifies the message M to M', the attacker can simply recompute H(M') and replace both. Because an unkeyed hash involves no secret key, it provides ZERO inherent message authenticity.
- To provide authenticity along with integrity, a secret key must be integrated into the hash calculation, creating a Keyed-Hash Message Authentication Code (HMAC) (Option d). In an HMAC, only entities possessing the shared secret key can compute or verify the valid tag. Thus, asserting that an unkeyed hash inherently provides authenticity is false.

Question 8 **In IPsec, which mode encrypts/protects only the payload (transport layer data) while keeping the original IP header intact?**

a. Tunnel mode
b. Transport mode
c. Replay mode
d. Confidential mode
e. None of these

Final True Answer: b.

Professor's Detailed Explanation:

Internet Protocol Security (IPsec) provides network-layer security operating in two primary modes:
1. Transport Mode (Option b): Protects the upper-layer payload (the transport layer segment, such as TCP/UDP and application data) while preserving the original IPv4/IPv6 header intact. It inserts the IPsec header (AH or ESP) directly between the original IP header and the transport layer data. It is primarily used for direct end-to-end host-to-host communications.
2. Tunnel Mode (Option a): Encrypts the ENTIRE original IP packet (both the original IP header and the payload) and encapsulates it inside a completely new outer IP header. This mode is the standard for site-to-site VPN gateways.

Question 9 **Hash digest size produced by the MD5 algorithm is _____ bits.**

Numerical input (Integer)

Final True Answer: 128

Professor's Detailed Explanation:

The Message Digest 5 (MD5) algorithm, designed by Ronald Rivest in 1991, processes input text in 512-bit blocks and produces an output hash digest of exactly 128 bits (16 bytes). In hexadecimal notation, this is rendered as a 32-character hex string. Although MD5 is cryptographically broken today due to practical collision vulnerabilities and should not be used for digital signatures or security certificates, it remains widely referenced in networking fundamentals.

Question 10 **The block size used by the SHA-512 hashing algorithm is _____ bits.**

Numerical input (Integer)

Final True Answer: 1024

Professor's Detailed Explanation:

The Secure Hash Algorithm (SHA-2) family features distinct internal structures based on word size:
- SHA-256 operates on 32-bit words, processing message blocks of 512 bits to produce a 256-bit digest.
- In contrast, SHA-512 operates on 64-bit words, processing input message blocks of exactly 1024 bits (128 bytes) per compression round to produce its 512-bit digest.

Input messages to SHA-512 are padded so that their length is a multiple of 1024 bits before entering the 80 rounds of hash computation.

Week 8: Steganography, Biometrics, Denial of Service Attacks, and PGP

Module Overview & Key Learning Objectives:

In Week 8, we explore information hiding and access controls: steganography concepts and LSB calculations, behavioral versus physiological biometrics, iris scanning reliability, DoS mechanisms (Smurf amplification, SYN flood half-open states), Pretty Good Privacy (PGP) hybrid cryptography, and DNS resolution.

Question 1 **Which of the following statements best describes steganography?**

a. Encrypting information using public and private keys.
b. Embedding information within another cover medium.
c. Tunnelling data using HTTPS and TLS.
d. Compressing data to reduce its transmission size.
e. None of these.

Final True Answer: b.

Professor's Detailed Explanation:

Steganography, derived from the Greek words 'steganos' (concealed or hidden) and 'graphein' (writing), is the art and science of hiding secret messages within an ordinary, non-secret carrier medium (such as digital images, audio files, video streams, or network protocol headers) so that an outside observer is unaware that any secret communication is taking place (Option b). While cryptography scrambles a message to make it unreadable (drawing attention to its confidential nature), steganography conceals the very existence of the message itself. The two techniques are frequently combined in modern security.

Question 2 **Which of the following are valid examples of steganography?**

a. Hiding text data within an image file.
b. Hiding secret data within an audio clip.
c. Encrypting a file so only the recipient can decrypt it.
d. Hiding data within an executable file.
e. Digitally signing a document to prove authorship.
f. None of these.

Final True Answer: a., b., d.

Professor's Detailed Explanation:

Valid steganographic implementations embed confidential payloads into cover media without noticeably altering the carrier's perceptual quality or standard execution:
- Option (a): Replacing the least significant bits of image pixels to embed confidential text is classic image steganography.
- Option (b): Modifying inaudible audio frequencies or LSBs in PCM audio files constitutes audio steganography.
- Option (d): Appending data to executable slack space or unused PE sections represents binary executable steganography.
In contrast, Option (c) is encryption (cryptography) and Option (e) is digital signing (authenticity), neither of which hides the existence of the communication.

Question 3 **Which of the following is/are examples of behavioural biometrics?**

a. Fingerprint
b. Signature dynamics
c. Gait
d. Iris pattern
e. Keystroke dynamics
f. Retina pattern
g. Facial structure

Final True Answer: b., c., e.

Professor's Detailed Explanation:

Biometric authentication modalities are classified into two broad categories:
1. Behavioral Biometrics: Measure unique behavioral patterns, habits, and dynamic actions performed by an individual over time. Examples include Signature Dynamics (measuring pen speed, pressure, and stroke rhythm, Option b), Gait analysis (measuring walking rhythm and body posture dynamics, Option c), and Keystroke Dynamics (measuring typing rhythm, key press duration, and flight time between keys, Option e).
2. Physiological Biometrics: Measure static, innate physical anatomical characteristics of the human body. Examples include Fingerprint ridge patterns (Option a), Iris patterns (Option d), Retina vascular patterns (Option f), and Facial structure/geometry (Option g).

Question 4 **Which biometric modality is generally considered to offer very high uniqueness and reliability for identification?**

a. Voice recognition
b. Facial recognition
c. Iris scan
d. Signature dynamics
e. Gait analysis

Final True Answer: c.

Professor's Detailed Explanation:

Among all mainstream biometric modalities, the human Iris (Option c) exhibits exceptionally high uniqueness, stability, and entropy. Formed during embryonic gestation through random morphogenesis, the complex epigenetic trabecular meshwork, crypts, furrows, and rings of the iris are unique even between identical twins and between a person's left and right eyes. Furthermore, unlike facial features (which age and change with expression) or voice/signature dynamics (which vary with illness or fatigue), the iris remains remarkably stable throughout an individual's lifetime, resulting in negligible False Match Rates (FMR) and unmatched reliability in large-scale identification systems.

Question 5 **What is a Denial-of-Service (DoS) attack?**

a. An attack that deletes or modifies files stored on a system.
b. An attack that prevents legitimate users from accessing a service.
c. An attack that specifically targets and destroys stored password databases.
d. None of these.

Final True Answer: b.

Professor's Detailed Explanation:

A Denial-of-Service (DoS) attack directly targets the Availability pillar of the CIA Triad. Its sole objective is to overwhelm, degrade, or completely disable a target host, server, application, or network link, rendering the service entirely inaccessible to legitimate, authorized users (Option b). This can be achieved through volumetric flooding (saturating available network bandwidth), protocol resource exhaustion (such as filling connection tables via SYN flooding), or software logic crashes (sending malformed packets that trigger unhandled buffer exceptions).

Question 6 **How does a Smurf DoS attack typically work?**

a. It sends oversized IP packets to crash the target host.
b. It sends forged ICMP Echo requests to a network's broadcast address with the victim's spoofed source IP, causing many hosts to flood the victim with replies.
c. It exploits buffer overflow vulnerability in web server software.
d. It uses SQL injections to compromise a backend database.
e. None of these.

Final True Answer: b.

Professor's Detailed Explanation:

The Smurf attack is a classic network-layer amplification and reflection Denial of Service attack. It operates as follows:
1. The attacker crafts ICMP Echo Request (ping) packets.
2. The attacker spoofs the source IP address in the IP header to match the victim's IP address.
3. The attacker transmits these spoofed packets to the directed broadcast address of an intermediary third-party network (known as the amplifier network).
4. All active workstations and servers on that intermediary network receive the broadcast request and dutifully generate ICMP Echo Reply packets directed back to the spoofed source IP (the victim).
5. The victim's incoming link is overwhelmed by a massive, amplified flood of unsolicited replies (Option b). Modern routers mitigate this by disabling directed broadcast forwarding (no ip directed-broadcast).

Question 7 **Which of the following attacks exploits the TCP three-way handshake by leaving connections in a half-open state?**

a. Ping of Death attack
b. SYN flooding attack
c. Smurf attack
d. DNS spoofing attack

Final True Answer: b.

Professor's Detailed Explanation:

A TCP SYN Flooding attack (Option b) exploits the stateful resource allocation inherent in the TCP three-way handshake:
- An attacker transmits a torrent of TCP SYN packets to a listening port on the target server, using spoofed or unreachable source IP addresses.
- For every incoming SYN, the server allocates kernel memory resources, creates an entry in its half-open connection queue (the backlog queue), and replies with a SYN-ACK packet.
- Because the source IP is spoofed or unresponsive, the final ACK packet is never sent.
- The server's backlog queue remains filled with half-open connections waiting for timeouts. Once the queue reaches its maximum capacity, the server is unable to accept legitimate incoming connection requests, denying service to real clients. Countermeasures include SYN Cookies, reduced timeouts, and firewall rate limiting.

Question 8 **What does PGP (Pretty Good Privacy) primarily provide for secure email communication?**

a. Authentication of the sender
b. Confidentiality of the message content
c. Guaranteed message availability
d. Protection against email spam filtering

Final True Answer: a., b.

Professor's Detailed Explanation:

Pretty Good Privacy (PGP), created by Phil Zimmermann, is the premier hybrid cryptosystem for email and file encryption:
- Confidentiality (Option b): PGP encrypts email body text and attachments using high-speed symmetric session encryption (like AES or IDEA), and then encrypts the symmetric session key with the recipient's public key (RSA or ElGamal).
- Authentication and Integrity (Option a): PGP hashes the message and encrypts the hash with the sender's private key, generating a digital signature that verifies the sender's identity and proves the message was not modified in transit.
PGP operates at the application layer and does not guarantee network availability or prevent spam filtering.

Question 9 **What is the primary purpose of the Domain Name System (DNS)?**

a. To provide end-to-end encryption for email communication.
b. To translate human-readable domain names into IP addresses.
c. To compress and fragment large network messages.
d. To hide secret data inside cover media files.
e. None of these.

Final True Answer: **b.**

Professor's Detailed Explanation:

The Domain Name System (DNS), operating over UDP and TCP port 53, serves as the phonebook of the Internet. Its primary purpose is translating human-memorable domain names (such as `www.nptel.ac.in` or `google.com`) into numerical IP addresses (such as `142.250.190.46` or `2404:6800:4009:830::200e`) required by network routers to deliver IP packets (Option b). DNS also provides reverse lookups (translating IPs to domain names via PTR records) and email routing directives via MX records.

Question 10 **Consider a grayscale image of size 1500 x 1200, where each pixel is stored using 8 bits. Using LSB steganography (1 bit hidden per pixel), how many bytes of information can be hidden in this image?**

Numerical input (Integer)

Final True Answer: **225000**

Professor's Detailed Explanation:

Let us compute the storage capacity using Least Significant Bit (LSB) steganography:
1. First, calculate the total number of pixels in the grayscale image:
Total Pixels = Width * Height = 1500 * 1200 = 1,800,000 pixels.
2. In a grayscale image, each pixel is represented by a single byte (8 bits). Under standard 1-bit LSB steganography, exactly 1 secret bit is substituted into the least significant bit of each pixel's byte.
3. Therefore, the total number of hidden bits is:
Total Hidden Bits = 1,800,000 pixels * 1 bit per pixel = 1,800,000 bits.
4. To convert bits to bytes, divide by 8:
Total Hidden Bytes = 1,800,000 bits / 8 bits per byte = 225,000 bytes.

Thus, exactly 225,000 bytes of secret data can be embedded within this image.

Week 9: Network Sniffing, Wireshark, Social Engineering, and ARP Spoofing

Module Overview & Key Learning Objectives:

Week 9 covers eavesdropping, traffic analysis, and human factors. We explore network sniffing mechanics, NIC promiscuous mode, Wireshark packet capture capabilities, cleartext protocol vulnerabilities, Ettercap MITM capabilities, human-based vs computer-based social engineering attacks, Slowloris HTTP DoS attacks, and ARP cache poisoning.

Question 1 **Which of the following statement(s) is/are true for sniffing?**

a. It is a process of analyzing network activity by capturing network traffic.
b. It is a process of finding vulnerabilities in a network.
c. It is a process used for user enumeration.
d. It may require the NIC to operate in promiscuous mode to capture frames not specifically addressed to the host.
e. None of these.

Final True Answer: a., d.

Professor's Detailed Explanation:

Network sniffing is the practice of capturing, logging, and analyzing data packets as they flow across a computer network (Option a). Under standard operating conditions, a Network Interface Card (NIC) inspects the destination hardware MAC address of incoming frames and immediately discards any frame that does not match its own MAC address or a broadcast/multicast address. To capture all network traffic traversing the physical medium regardless of destination, the NIC must be configured in Promiscuous Mode (Option d). Sniffing by itself is a passive monitoring activity; active vulnerability discovery (Option b) is the role of vulnerability scanners, and user enumeration (Option c) is performed through active directory or service querying.

Question 2 **Which of the following is/are not a feature of Wireshark?**

a. Capturing and analyzing network packets.
b. Generating statistical reports on captured traffic.
c. Manipulating and modifying live network traffic.
d. Displaying packet details with GUI support.
e. Carrying out SQL injection attacks.
f. Filtering captured packets by protocol.

Final True Answer: c., e.

Professor's Detailed Explanation:

Wireshark is the world's most widely used open-source network protocol analyzer. It operates as a passive inspection tool: capturing packets in real time from network interfaces, dissecting hundreds of protocol headers, providing rich graphical displays, applying complex display filters, and generating statistical flow summaries (Options a, b, d, and f are all genuine Wireshark features).

Crucially, Wireshark is strictly passive: it CANNOT alter, tamper with, or inject packets into live network streams (Option c), and it is not an exploit framework for executing SQL injection attacks (Option e). Tools like Ettercap or Burp Suite manipulate live traffic, and tools like SQLMap execute SQL injection attacks. Thus, (c) and (e) are correct answers to this 'not a feature' question.

Question 3 **Which of the following protocols are vulnerable to sniffing attacks?**

a. HTTP
b. FTP
c. Telnet
d. HTTPS
e. SSL
f. SSH

Final True Answer: a., b., c.

Professor's Detailed Explanation:

Protocols that transmit authentication credentials, session tokens, and data payloads in cleartext (unencrypted plaintext) across the wire are completely vulnerable to packet sniffing attacks:
- HTTP (Hypertext Transfer Protocol, Option a): Transmits web requests, cookies, and form data in plaintext.
- FTP (File Transfer Protocol, Option b): Sends usernames and passwords across port 21 without encryption.
- Telnet (Option c): Sends all terminal keystrokes, including administrative login credentials, in cleartext.
Anyone running a packet sniffer like Wireshark or tcpdump on the local network segment can intercept these credentials effortlessly. In contrast, HTTPS, SSL/TLS, and SSH (Secure Shell) encrypt all traffic end-to-end, rendering sniffed payload data cryptographically unreadable.

Question 4 **Which of the following feature(s) is/are not present in the Ettercap tool?**

a. IP-based and MAC-based filtering.
b. Character injection into live connections.
c. Packet filtering and dropping.
d. SQL injection automation.
e. Password cracking via dictionary attack.

Final True Answer: d., e.

Professor's Detailed Explanation:

Ettercap is a specialized suite designed for Man-in-the-Middle (MITM) attacks on switched local area networks. It features native support for ARP poisoning, ICMP redirects, packet sniffing, IP/MAC filtering (Option a), packet dropping (Option c), and live character substitution/injection into established connections using Ettercap filter scripts (Option b).

However, Ettercap is NOT an automated SQL injection tool (Option d, which is the domain of SQLMap) and it is NOT an offline dictionary password hash cracker (Option e, which is the domain of John the Ripper and Hashcat). Therefore, (d) and (e) are the features not present in Ettercap.

Question 5 **Which of the following is not a human-based social engineering attack?**

a. Impersonation
b. Shoulder surfing
c. Piggybacking/tailgating
d. Phishing email

Final True Answer: d.

Professor's Detailed Explanation:

Social engineering attacks manipulate human psychology rather than software vulnerabilities to breach security, and they are split into human-based and computer-based approaches:
- Human-based social engineering involves direct, face-to-face, or voice interpersonal interaction. Examples include Impersonation (pretending to be an IT technician or executive, Option a), Shoulder Surfing (looking over someone's shoulder in person to observe passwords, Option b), and Piggybacking/Tailgating (closely following an authorized employee through a secure physical door, Option c).
- In contrast, Phishing emails (Option d) are computer-based social engineering attacks, executed through electronic mail communication using fraudulent hyperlinks and deceptive attachments.

Question 6 **A DoS attack that exploits the TCP three-way handshake by leaving connections incomplete is called:**

a. SYN Flooding
b. ICMP Flood
c. Ping of Death
d. UDP Flood

Final True Answer: a.

Professor's Detailed Explanation:

A TCP SYN Flooding attack (Option a) specifically exploits the handshake state machine of the Transmission Control Protocol. The adversary floods the target server with TCP SYN packets containing spoofed source IP addresses. The server allocates memory in its connection table (backlog queue) and transmits SYN-ACK packets. Because the source addresses are spoofed, the expected final ACK packets never arrive, leaving the connections in a 'half-open' (SYN_RECV) state. The backlog queue quickly becomes exhausted, preventing legitimate users from establishing new TCP connections. ICMP floods and UDP floods are volumetric traffic attacks, while Ping of Death involves malformed, oversized IP packets.

Question 7 **Which tool is specifically known for performing DoS attacks by sending partial HTTP requests and never completing them?**

a. Hydra
b. Wireshark
c. Slowloris
d. Crunch

Final True Answer: c.

Professor's Detailed Explanation:

Slowloris (Option c) is a highly effective, low-bandwidth application-layer Denial of Service attack tool created by Robert Hansen. Rather than relying on massive bandwidth volumetric flooding, Slowloris exploits connection limits in thread-based web servers (like Apache 1.x and 2.x). It opens hundreds of HTTP connections and sends partial HTTP GET headers (for example, `X-a: b\r\n`) at regular, slow intervals just before the server's timeout window expires. Because the HTTP headers are never completed with a final blank line (`\r\n\r\n`), the web server holds each connection open waiting for the rest of the request, quickly consuming the entire concurrent connection pool and denying access to legitimate visitors.

Question 8 **Which mode allows a network interface card (NIC) to capture frames that are not specifically addressed to the host?**

a. Monitor mode
b. Transparent mode
c. Promiscuous mode
d. Bridge mode

Final True Answer: c.

Professor's Detailed Explanation:

Promiscuous mode (Option c) is a controller configuration mode that instructs a wired or wireless network interface card to pass every received frame to the central operating system kernel, regardless of whether the frame's destination MAC address matches the interface's own MAC address, a broadcast address, or a multicast address. This mode is the essential prerequisite for software packet sniffers like Wireshark and tcpdump on wired Ethernet networks. (Note: Monitor mode, Option a, is specific to wireless 802.11 NICs to capture raw radio frames without associating with an Access Point).

Question 9 **Which of the following is/are examples of computer-based social engineering attacks?**

a. Phishing emails
b. Pop-up window scams
c. Shoulder surfing
d. Chain letter emails
e. Tailgating

Final True Answer: a., b., d.

Professor's Detailed Explanation:

Computer-based social engineering attacks rely on digital computing interfaces and internet communication channels to manipulate victims:
- Phishing emails (Option a): Fraudulent electronic mail mimicking trusted institutions to steal credentials.
- Pop-up window scams (Option b): Browser pop-ups claiming system infection to trick users into downloading fake antivirus malware or calling fake support numbers.
- Chain letter emails (Option d): Deceptive digital messages that manipulate users into forwarding content to their contacts.
In contrast, Shoulder Surfing (Option c) and Tailgating (Option e) are strictly human-based, physical attacks occurring in the real physical environment.

Question 10 **What is the primary purpose of ARP spoofing in the context of sniffing attacks?**

a. To increase the bandwidth available to the attacker.
b. To redirect traffic between two hosts through the attacker's machine for interception.
c. To encrypt network traffic for secure transmission.
d. To permanently disable a target host's network interface.

Final True Answer: b.

Professor's Detailed Explanation:

On a modern switched Ethernet network, switches send unicast traffic only to the designated destination port, preventing simple passive sniffing. To bypass this, an attacker employs ARP Spoofing (ARP Poisoning). Because the Address Resolution Protocol (ARP) lacks authentication, the attacker transmits gratuitous, forged ARP reply packets to both the victim host and the local default gateway:
- Telling the victim that the gateway's IP address is mapped to the attacker's MAC address.
- Telling the gateway that the victim's IP address is mapped to the attacker's MAC address.
Both parties update their internal ARP caches with these poisoned entries. Consequently, all bidirectional traffic between the victim and the external Internet is transparently routed through the attacker's machine, enabling full traffic interception, eavesdropping, and modification (Option b).

Week 10: Hardware Security, Side-Channel Attacks, PUFs, and Hardware Trojans

Module Overview & Key Learning Objectives:

Week 10 ventures into hardware security and cryptographic implementation vulnerabilities. We analyze physical attacks, side-channel leakage (timing, power, electromagnetic), the square-and-multiply algorithm, Simple vs Differential Power Analysis (SPA/DPA), Physically Unclonable Functions (PUFs), Hardware Trojans, invasive probing, and software constant-time mitigations.

Question 1 **Which of the following are examples of hardware-based attacks?**

a. Physical probing
b. SQL injection
c. Cross-site scripting
d. Electromagnetic emission analysis
e. Phishing

Final True Answer: a., d.

Professor's Detailed Explanation:

Hardware-based attacks directly target the physical silicon chip, integrated circuit package, or hardware emanations of a computing device:
- Physical probing (Option a): An invasive attack where a technician depackages an integrated circuit and places microscopic needle probes directly onto internal silicon metal traces to eavesdrop on bus signals or memory buses.
- Electromagnetic emission analysis (Option d): A non-invasive side-channel attack that captures and decodes unintended electromagnetic radiation leaking from cryptographic processing cores.
In contrast, SQL Injection (Option b) and Cross-Site Scripting (Option c) are web application software vulnerabilities, and Phishing (Option e) is a social engineering attack.

Question 2 **Which of the following statement(s) is/are true regarding side-channel attacks?**

a. They exploit weaknesses in the implementation of an algorithm, not the algorithm itself.
b. They may require physical access to (or close proximity to) the target device, depending on the side channel being exploited.
c. They rely solely on analyzing input/output pairs of the algorithm.
d. They can exploit information such as timing, power consumption, or electromagnetic emissions.
e. They exploit mathematical weaknesses in the cryptographic algorithm's design.

Final True Answer: a., b., d.

Professor's Detailed Explanation:

Side-channel attacks represent a critical paradigm shift in cryptanalysis. Traditional mathematical cryptanalysis attempts to break the abstract mathematical design of an algorithm (like factoring RSA moduli or discovering linear differentials in AES). In contrast, side-channel attacks exploit physical information leaked by the physical implementation of the cryptosystem on physical hardware (Option a). When a silicon chip processes data, it leaks observable physical side-channel signals: variations in execution time, dynamic power consumption fluctuations, acoustic noise, and electromagnetic radiation (Option d). Capturing these physical emanations often requires physical access or close proximity (Option b). Option (c) is false because treating the cipher purely as an input/output black box is the definition of classical cryptanalysis, which side channels bypass entirely.

Question 3 **For modular exponentiation of x^22 using the square-and-multiply method, how many squaring and multiplication operations are required, respectively?**

a. 4 and 2
b. 3 and 2
c. 4 and 3
d. 5 and 2
e. 3 and 3

Final True Answer: a.

Professor's Detailed Explanation:

Let us solve this classic cryptographic computation step by step. We want to compute x^22 using the left-to-right binary square-and-multiply algorithm.

Step 1: Express the exponent (22) in binary:
22 in binary = 16 + 4 + 2 = (10110) in base 2.
The binary string has 5 bits: b4=1, b3=0, b2=1, b1=1, b0=0.

Step 2: Trace the algorithm from left to right (from the second most significant bit down to the least significant bit):
- Initialize accumulator: Start with bit b4 = 1, setting Accumulator = x.
- Bit 3 (0): Square: Accumulator = (x)^2 = x^2. (Squaring 1, Multiplication 0).
- Bit 2 (1): Square: Accumulator = (x^2)^2 = x^4. (Squaring 2).
  Multiply by x: Accumulator = x^4 * x = x^5. (Multiplication 1).
- Bit 1 (1): Square: Accumulator = (x^5)^2 = x^10. (Squaring 3).
  Multiply by x: Accumulator = x^10 * x = x^11. (Multiplication 2).
- Bit 0 (0): Square: Accumulator = (x^11)^2 = x^22. (Squaring 4, Multiplication 0).

Step 3: Tally the operations:
Total Squaring operations = 4 (for each bit after the first bit: 5 - 1 = 4).
Total Multiplication operations = 2 (for each '1' bit after the first bit: bits b2 and b1).
Therefore, exactly 4 squaring and 2 multiplication operations are required, matching Option (a).

Question 4 **Which of the following statement(s) is/are true regarding Differential Power Analysis (DPA) and Simple Power Analysis (SPA)?**

a. DPA requires only a single power trace measurement.
b. DPA requires multiple power trace measurements combined with statistical analysis.
c. DPA uses statistical analysis of multiple traces to reveal information that may not be apparent from individual traces.
d. DPA is generally less effective than SPA.
e. SPA relies on directly observing patterns in a single or few traces.

Final True Answer: b., c., e.

Professor's Detailed Explanation:

Power analysis attacks monitor the instantaneous power consumption of a cryptographic device (such as a smartcard or microcontroller) during execution:
- Simple Power Analysis (SPA, Option e): Involves directly inspecting visual variations in a single power trace (or a small handful of traces) over time. For example, in the square-and-multiply algorithm, a multiplication operation often draws noticeably different power or takes longer than a squaring operation, allowing an observer to visually read the private exponent bits directly off an oscilloscope screen.
- Differential Power Analysis (DPA, Options b and c): Is a much more sophisticated and powerful statistical technique. When power variations are subtle and buried beneath high circuit noise, SPA fails. DPA collects thousands of power traces across varying ciphertexts, formulates cryptographic hypotheses about small subkeys, and uses statistical tools (such as difference of means or Pearson correlation) to extract secret keys. DPA is vastly more powerful and resilient than SPA.

Question 5 **Which property of a PUF refers to the requirement that, given a PUF and an input (challenge) x, its corresponding output (response) y = PUF(x) can be computed efficiently?**

a. Unclonability
b. One-wayness
c. Evaluability
d. Unpredictability
e. Tamper-evidence

Final True Answer: c.

Professor's Detailed Explanation:

A Physically Unclonable Function (PUF) is a physical structure embedded within an integrated circuit that exploits microscopic, uncontrollable manufacturing process variations to generate unique device signatures. A standard PUF must satisfy several formal properties:
- Evaluability (Option c): Given the physical PUF hardware and a challenge input x, evaluating and producing the corresponding response y = PUF(x) must be fast, computationally lightweight, and easy to perform by the physical system.
- Unclonability (Option a): It must be physically and technologically impossible to construct an identical physical clone of the PUF that produces the same responses.
- Unpredictability (Option d): Given a set of known challenge-response pairs, it must be computationally infeasible to predict the response to a new challenge without physically evaluating the PUF.

Question 6 **____ is the full form of the acronym PUF used in hardware security.**

a. Physically Unique Function
b. Physically Unclonable Function
c. Protected Unclonable Feature
d. Physically Untraceable Function

Final True Answer: b.

Professor's Detailed Explanation:

PUF stands for Physically Unclonable Function (Option b). Often described as the 'silicon biometric' or digital fingerprint of an integrated circuit, a PUF derives its uniqueness from sub-micron manufacturing variations (such as gate oxide thickness fluctuations, threshold voltage mismatches, and parasitic interconnect wiring delays) introduced randomly during semiconductor fabrication. Common designs include SRAM PUFs (evaluating power-up cross-coupled inverter states), Ring Oscillator PUFs, and Arbiter PUFs. They are used for secure cryptographic key generation and anti-counterfeiting authentication without storing secret keys in non-volatile memory.

Question 7 **What is a hardware Trojan?**

a. A malicious software virus that specifically targets firmware update files.
b. A malicious, intentional modification to a chip's circuitry that activates under specific trigger conditions.
c. A testing tool used to validate hardware functionality before shipping.
d. A feature designed to make hardware run faster under heavy load.

Final True Answer: b.

Professor's Detailed Explanation:

A Hardware Trojan is a malicious, stealthy, and intentional alteration of an integrated circuit's design or physical manufacturing mask, typically inserted during untrusted design, third-party IP core integration, or offshore semiconductor foundry fabrication (Option b). A hardware Trojan consists of two components: a Trigger (a dormant sensing mechanism, such as a counter reaching a rare value or a specific data pattern on a bus) and a Payload (the malicious action, which activates to leak cryptographic keys through side channels, degrade reliability, or disable system security controls). Because they are fabricated directly in silicon, hardware Trojans bypass software security scanners entirely.

Question 8 **Which of the following statement(s) is/are true regarding hardware Trojans?**

a. They typically incur small hardware overhead, making them difficult to detect.
b. They are generally easy to detect using a single, universal detection method.
c. Detecting hardware Trojans often introduces additional design, testing, or runtime overhead.
d. Hardware Trojans are exclusively inserted through software-level modifications.

Final True Answer: a., c.

Professor's Detailed Explanation:

Let us evaluate the security challenges posed by hardware Trojans:
- Statement (a) is true: Adversaries intentionally design hardware Trojans to occupy a tiny physical silicon footprint (often adding only a handful of logic gates among hundreds of millions on a modern SoC). This minimal physical footprint produces negligible changes in power or delay, making detection exceptionally difficult.
- Statement (c) is true: Defensive verification strategies (such as pre-silicon formal verification, destructive reverse-engineering, side-channel fingerprinting, or built-in on-chip runtime monitoring logic) inevitably add significant silicon area, testing time, financial cost, and power overhead.
- Statement (b) is false: No universal detection method exists; multiple complementary techniques are required.
Statement (d) is false: hardware Trojans are physical circuit modifications, not software modifications.

Question 9 **Which of the following hardware attack(s) are generally considered invasive in nature?**

a. Black-box testing
b. Physical probing
c. Side-channel power analysis
d. Timing analysis

Final True Answer: b.

Professor's Detailed Explanation:

Hardware security attacks are categorized based on their level of physical disruption:
1. Invasive Attacks (Option b): Require permanently breaching or modifying the physical packaging of the chip. Physical probing involves decapsulating the protective plastic/ceramic resin using fuming nitric acid, polishing away passivation layers, and placing microprobes directly onto internal sub-micron wiring under a scanning electron microscope. This process leaves irreversible physical damage.
2. Semi-invasive Attacks: Require decapsulation (e.g., exposing the die to ultraviolet light or focused laser beams for fault injection), but do not establish direct mechanical contact with the circuitry.
3. Non-invasive Attacks: Rely purely on standard electrical pins or external side-channel leakages without physically damaging the chip package (such as black-box testing in Option a, power analysis in Option c, and timing analysis in Option d).

Question 10 **Which of the following software-level technique(s) can help mitigate timing-based side-channel attacks?**

a. Introducing redundant/dummy computations to equalize execution time across branches.
b. Masking sensitive intermediate data values during computation.
c. Deliberately increasing overall program complexity without addressing timing variance.
d. Ensuring constant-time implementations for security-critical operations.

Final True Answer: a., d.

Professor's Detailed Explanation:

Timing side-channel attacks exploit variations in execution duration caused by conditional branches, early exits, or cache hit/miss latency that correlate with secret cryptographic key bits. To eliminate this leakage at the software implementation level:
- Option (d): Implement strictly constant-time code. Software must be written so that every execution path takes the exact same number of clock cycles regardless of secret inputs (avoiding secret-dependent conditional branches and secret-dependent memory lookup tables).
- Option (a): Equalize timing across branches by inserting balanced dummy or redundant computations so that the execution time of an 'if' branch and an 'else' branch are identical.
- Option (b) (Masking) is a defense primarily against power analysis (DPA) rather than timing attacks. Option (c) is security through obscurity and does not resolve timing differentials.

Week 11: Penetration Testing Frameworks, Web Attacks, SQL Injection, and XSS

Module Overview & Key Learning Objectives:

Week 11 immerses us in penetration testing tools and web application security: Metasploit module architecture (exploit, payload, auxiliary, encoder), msfconsole interaction, target compatibility, Meterpreter post-exploitation commands, web directory brute-forcing (DIRB), error-based SQL injection, automated database enumeration via SQLMap, Cross-Site Scripting (XSS) taxonomy, and SQL injection authentication bypass payloads.

Question 1 **Which of the following Metasploit modules is used to take advantage of a known vulnerability on a target system?**

a. Payload
b. Exploit
c. Encoder
d. Auxiliary

Final True Answer: b.

Professor's Detailed Explanation:

In the Metasploit Framework architecture, an Exploit module (Option b) is the specific piece of software or script designed to target and leverage a known software flaw, misconfiguration, or bug on a remote target system (for example, a buffer overflow in an SMB service or an unauthenticated remote code execution vulnerability in a web server). The exploit's sole responsibility is delivering and executing arbitrary code on the target.

Let us clarify the roles of the other Metasploit modules:
- Payload (Option a): The actual code executed on the target system AFTER the exploit succeeds (such as a command shell or Meterpreter session).
- Encoder (Option c): Obfuscates payloads to evade signature-based detection by antivirus and IDS solutions (e.g., `x86/shikata_ga_nai`).
- Auxiliary (Option d): Performs scanning, sniffing, port probing, and fingerprinting without executing an exploitation payload.

Question 2 **Which command is used to launch the Metasploit Framework console?**

a. msfvenom
b. msfconsole
c. metasploit-cli
d. msf-start

Final True Answer: b.

Professor's Detailed Explanation:

The primary, all-in-one interactive command-line interface for the Metasploit Framework is launched using the command `msfconsole` (Option b). It provides a unified scripting and management environment containing all exploit, auxiliary, post-exploitation, payload, and encoder modules with interactive tab-completion and database management. Reviewing the distractors: `msfvenom` (Option a) is Metasploit's standalone command-line payload generation and encoding utility; `metasploit-cli` and `msf-start` are non-existent commands.

Question 3 **Which Metasploit command is used to check which target operating systems are compatible with a selected exploit?**

a. show targets
b. set targets
c. check compatibility
d. show exploits
e. show payloads

Final True Answer: a.

Professor's Detailed Explanation:

Once an exploit module is loaded in Metasploit (via `use exploit/...`), executing the command `show targets` (Option a) displays a comprehensive list of specific target operating systems, service pack versions, architectures, and return address offsets supported by that exploit (for example, target 0 for Automatic, target 1 for Windows XP SP2, target 2 for Windows XP SP3). The penetration tester then uses `set TARGET <number>` to select the appropriate target. In contrast, `show exploits` lists all exploits in the framework, and `show payloads` displays payloads compatible with the current exploit.

Question 4 **Which Metasploit option is used to specify the target's IP address (the remote host to be attacked)?**

a. set LHOST
b. set LPORT
c. set RHOST
d. set RPORT

Final True Answer: c.

Professor's Detailed Explanation:

In Metasploit conventions:
- `RHOST` (Remote Host, Option c) or `RHOSTS` defines the IP address or hostname of the remote target system being probed or attacked.
- `RPORT` (Remote Port, Option d) specifies the remote target port on which the vulnerable daemon is listening.
- `LHOST` (Local Host, Option a) specifies the IP address of the penetration tester's attacking system, required by reverse-shell payloads to connect back to the attacker.
- `LPORT` (Local Port, Option b) specifies the listening port on the attacker's machine waiting for that inbound connection.

Question 5 **Which command in Metasploit's Meterpreter shell is used to retrieve stored user account password hashes from the target system?**

a. Getuid
b. Getsystem
c. Hashdump
d. Sysinfo
e. ps

Final True Answer: c.

Professor's Detailed Explanation:

Meterpreter is Metasploit's advanced, dynamically extensible in-memory post-exploitation payload. Once an active Meterpreter session is established with administrative or SYSTEM privileges on a Windows target, entering the command `hashdump` (Option c) dumps the NTLM and LM password hashes of local user accounts directly from the Security Account Manager (SAM) database or memory. These hashes can then be cracked offline or used in Pass-the-Hash attacks. Reviewing the other commands: `getuid` displays the current user token; `getsystem` attempts automated privilege escalation to NT AUTHORITY\SYSTEM; `sysinfo` displays host OS details; and `ps` lists running processes.

Question 6 **Which tool is specifically designed to perform brute-force discovery of hidden files and directories on a web server?**

a. SQLMAP
b. Dirb
c. Hydra
d. Crunch
e. Hashcat

Final True Answer: b.

Professor's Detailed Explanation:

DIRB (Option b) is an automated web content scanner designed specifically for directory and file enumeration on web servers. It launches a dictionary-based attack against a target web server, sequentially requesting URLs formulated from a comprehensive wordlist and evaluating HTTP response codes (such as HTTP 200 OK, 301 Redirect, or 403 Forbidden) to uncover unlinked admin portals, backup files, configuration archives, and hidden directories. Reviewing the other options: SQLMap automates SQL injection; Hydra brute-forces network logins; Crunch generates wordlists; and Hashcat cracks password hashes.

Question 7 **If a web page is vulnerable to error-based SQL injection, what is the expected behavior upon incorrect/malicious user input?**

a. It will display a database error message revealing information about the query structure.
b. It will silently return no output at all.
c. It will redirect the user to a login page automatically.
d. It will crash the entire web server permanently.

Final True Answer: a.

Professor's Detailed Explanation:

Error-based SQL injection is an in-band injection technique that relies on verbose, improperly handled database error messages returned directly by the web application. When an attacker inputs malformed characters (such as an unmatched single quote `'`), the backend database engine encounters a syntax error. If the web application displays this raw database error message on the user's screen, it inadvertently reveals table names, column names, database engine versions, and structural query syntax to the attacker (Option a). Attackers can deliberately trigger complex conversion errors to force the database to display sensitive data inside the error string.

Question 8 **Which SQLMAP option is used to list all database names available on the target system?**

a. - tables
b. - dbs
c. - dump
d. - current-db
e. - passwords

Final True Answer: b.

Professor's Detailed Explanation:

SQLMap is the open-source penetration testing tool that automates the detection and exploitation of SQL injection flaws. Once an injection vector is confirmed, the flag ` - dbs` (Option b) instructs SQLMap to enumerate and output the names of all databases present on the database management system. Reviewing related SQLMap flags: ` - current-db` retrieves only the name of the currently connected database; ` - tables` enumerates tables within a database; ` - columns` enumerates column headers; and ` - dump` extracts and downloads the actual table row records.

Question 9 **Which of the following is/are recognized types of Cross-Site Scripting (XSS) attacks?**

a. Stored XSS
b. Reflected XSS
c. DOM-based XSS
d. SQL-based XSS
e. Cookie-injection XSS

Final True Answer: a., b., c.

Professor's Detailed Explanation:

Cross-Site Scripting (XSS) occurs when an application includes untrusted user data in a web page without proper validation or escaping, allowing client-side scripts (typically JavaScript) to execute in the victim's browser. The industry-standard classification defines three core types of XSS:
1. Stored XSS (Persistent XSS, Option a): The malicious script is permanently stored on the target server (in a database, comment field, or message board) and served to every user who visits the page.
2. Reflected XSS (Non-persistent XSS, Option b): The malicious payload is reflected off the web server in an immediate HTTP response, typically embedded in a malicious phishing URL or search query parameter.
3. DOM-based XSS (Option c): The vulnerability exists entirely in the client-side Document Object Model (DOM), where client-side JavaScript reads data from a controllable source (such as `window.location`) and writes it to an execution sink (such as `document.write` or `element.innerHTML`) without server involvement.
Options (d) and (e) are non-standard fabricated terms.

Question 10 **Consider the following simplified query used by a login form: SELECT * FROM users WHERE username = 'INPUT1' AND password = 'INPUT2'. Which of the following input(s) for the username field, if unsanitized, would represent a classic SQL injection attempt to bypass authentication?**

a. admin
b. admin' OR '1'='1
c. admin123
d. ' OR 1=1 -
e. guest_user

Final True Answer: b., d.

Professor's Detailed Explanation:

Let us examine how unvalidated inputs alter the boolean logic of the backend SQL query:

Input (b): `admin' OR '1'='1`
Substituting this input into the query for INPUT1 yields:
`SELECT * FROM users WHERE username = 'admin' OR '1'='1' AND password = 'INPUT2'`
Because the boolean condition `'1'='1'` evaluates to TRUE for every single row in the database, the WHERE clause evaluates to TRUE, bypassing the password requirement entirely and logging the attacker in as the first user in the table.

Input (d): `' OR 1=1 - `
Substituting this input into the query yields:
`SELECT * FROM users WHERE username = '' OR 1=1 - ' AND password = 'INPUT2'`
The single quote terminates the literal string; `OR 1=1` forces the clause to evaluate to TRUE; and the double hyphen ` - ` (SQL comment sequence) causes the database engine to treat the rest of the query (including the password verification check) as a comment, discarding it completely.

Both inputs represent classic, textbook SQL injection authentication bypass vectors. Inputs (a), (c), and (e) are benign literal strings that do not break SQL syntax.

Week 12: Host Discovery Sweeps, Advanced Nmap Scanning, and Port Topologies

Module Overview & Key Learning Objectives:

In our concluding module, we examine advanced network scanning and host discovery methodologies using Nmap: ICMP response types, TCP ping sweeps (-PS, -PA), the behavior of the -sn ping scan flag, the host discovery bypass flag (-Pn), fast port scanning (-F), UDP scanning mechanics (-sU), the full three-way handshake TCP Connect scan (-sT), top-ports parameterization, and list scan (-sL) address range calculations.

Question 1 **In an ICMP Echo sweep, if the scanner receives an ICMP Type 0 packet in response to an ICMP Type 8 request, what does this indicate?**

a. The target host is alive/up
b. The target host is down
c. The target port is filtered
d. The target host does not support ICMP

Final True Answer: a.

Professor's Detailed Explanation:

In the Internet Control Message Protocol (ICMP, RFC 792), Type 8 represents an Echo Request, and Type 0 represents an Echo Reply. In a network ping sweep, an ethical hacker transmits an ICMP Type 8 datagram to a target IP address. If the target host is active, connected to the network, and has an operating system whose networking stack is configured to reply without being filtered by an intermediate firewall, it returns an ICMP Type 0 packet. The arrival of this Type 0 reply confirms definitively that the target host is online ('alive/up', Option a).

Question 2 **Which of the following NMAP option(s) can be used to perform a TCP-based sweep for host discovery?**

a. -PE
b. -PS
c. -PA
d. -PU
e. -PM

Final True Answer: b., c.

Professor's Detailed Explanation:

When performing host discovery against firewalled networks, ICMP pings are frequently blocked. Nmap provides TCP-based discovery sweeps to bypass stateless packet filters:
- `-PS` (TCP SYN Ping, Option b): Sends a raw TCP segment with the SYN flag set to probe if a host is up. If the target port is open, the host replies with SYN-ACK; if closed, it replies with RST. Either reply confirms host liveness.
- `-PA` (TCP ACK Ping, Option c): Sends a TCP packet with the ACK flag set. A live target host, recognizing that no prior connection exists, will return an RST packet, confirming it is active. This often evades firewalls configured to permit established sessions.
- Reviewing the distractors: `-PE` is ICMP Echo request; `-PU` is UDP ping; and `-PM` is ICMP Address Mask request. Only `-PS` and `-PA` utilize TCP for host discovery.

Question 3 **Which of the following are automatically performed when using the NMAP -sn option?**

a. ICMP Echo sweep
b. TCP sweep
c. UDP sweep
d. All of these

Final True Answer: a., b.

Professor's Detailed Explanation:

The Nmap `-sn` option (historically known as `-sP`) specifies a 'Ping Scan', instructing Nmap to perform host discovery only without port scanning the targets. When `-sn` is executed by a privileged (root) user against remote external IP targets, Nmap automatically initiates a multi-probe discovery suite comprising:
1. An ICMP Echo Request (`-PE`).
2. A TCP SYN packet sent to port 443 (`-PS443`).
3. A TCP ACK packet sent to port 80 (`-PA80`).
4. An ICMP Timestamp Request (`-PP`).

Thus, Nmap automatically conducts BOTH an ICMP Echo sweep (Option a) and a TCP sweep (Option b). It does NOT perform a UDP sweep (Option c), because UDP pings (`-PU`) are notoriously slow and are only executed when explicitly requested by the user. Therefore, Options (a) and (b) are both performed.

Question 4 **Which NMAP option treats all hosts as online, effectively skipping the host discovery phase?**

a. -sL
b. -sP
c. -P0
d. -sU
e. -Pn

Final True Answer: e. (also historically c. -P0)

Professor's Detailed Explanation:

Many modern enterprise firewalls block all ping probes (ICMP, TCP 80/443), causing Nmap's default host discovery phase to conclude that active hosts are completely offline. To circumvent this, Nmap provides the `-Pn` option (Option e). The `-Pn` flag instructs Nmap: 'Treat all hosts as online - skip host discovery entirely.' When `-Pn` is specified, Nmap completely bypasses the ping sweep and immediately launches port scans directly against every targeted IP address.

Historical note for the student: In early Nmap versions, this flag was originally named `-P0` (Option c) and `-PN`. While modern Nmap retains `-P0` as a backward-compatible alias, `-Pn` is the official modern syntax. Both refer to this vital host discovery bypass functionality.

Question 5 **Consider the following statements: (i) -sn performs host discovery only, without any port scanning. (ii) -Pn skips host discovery entirely and proceeds directly to port scanning.**

a. Only (i) is true
b. Only (ii) is true
c. Both (i) and (ii) are true
d. Both (i) and (ii) are false

Final True Answer: c.

Professor's Detailed Explanation:

Let us analyze both statements carefully:
- Statement (i): The `-sn` switch (No port scan) explicitly disables port scanning after the host discovery phase completes. It reports which IP addresses on the subnet are active and then terminates immediately. Statement (i) is completely TRUE.
- Statement (ii): The `-Pn` switch (No ping) explicitly turns off the host discovery phase, assuming every specified target host is powered on and active, proceeding straight into port scanning. Statement (ii) is completely TRUE.
Because both statements accurately define their respective Nmap options, Option (c) ('Both (i) and (ii) are true') is the correct answer.

Question 6 **Which of the following statement(s) is/are true regarding NMAP's -F (fast scan) option?**

a. It scans the top 100 most common ports.
b. It scans all 65535 ports.
c. It is faster than a default scan because it checks fewer ports.
d. It is equivalent to using - top-ports 1000

Final True Answer: a., c.

Professor's Detailed Explanation:

By default, when no specific port flags are provided, Nmap scans the top 1000 most common ports listed in its internal `nmap-services` database file:
- When the `-F` (Fast scan) option is specified, Nmap restricts the scan to only the top 100 most common ports (Option a is true).
- Because probing 100 ports requires 90% fewer network round-trip transmissions than probing 1000 ports, the scan executes significantly faster (Option c is true).
- Option (b) is false because scanning all 65535 ports requires the `-p-` flag. Option (d) is false because the default scan is equivalent to ` - top-ports 1000`, whereas `-F` is equivalent to ` - top-ports 100`.

Question 7 **Which NMAP option is specifically used to conduct a UDP port scan?**

a. -sT
b. -sS
c. -sU
d. -sA
e. -sN

Final True Answer: c.

Professor's Detailed Explanation:

The `-sU` option (Option c) instructs Nmap to execute a UDP port scan. Because UDP is connectionless, Nmap sends empty UDP packets to target ports. If an ICMP Port Unreachable error (Type 3, Code 3) is returned, the port is marked `closed`. If a service replies with a UDP packet, the port is marked `open`. If no response is received, the port is marked `open|filtered`.

Let us review the remaining Nmap scan options:
- `-sT`: TCP Connect scan.
- `-sS`: TCP SYN stealth scan.
- `-sA`: TCP ACK scan (used for firewall rule mapping).
- `-sN`: TCP Null scan (no flags set).

Question 8 **Which scanning technique completes the full TCP three-way handshake with the target port to determine its state?**

a. TCP SYN scan
b. TCP Connect scan
c. FIN scan
d. NULL scan
e. Xmas scan

Final True Answer: b.

Professor's Detailed Explanation:

The TCP Connect scan (Nmap option `-sT`, Option b) uses the operating system's standard high-level network API by issuing the `connect()` system call against each target port. It establishes the full, complete TCP three-way handshake:
1. Scanner sends SYN.
2. Target replies with SYN-ACK.
3. Scanner sends ACK (completing the handshake).
4. The connection is then cleanly closed using RST or FIN.
Because this uses standard system calls, unprivileged non-root users can execute it without raw packet access; however, because the connection completes fully, it is easily logged by target application servers. In contrast, the TCP SYN scan (`-sS`) tears down the connection before the final ACK, and FIN/NULL/Xmas scans send non-standard flag combinations.

Question 9 **How many ports will be scanned using the NMAP command 'nmap - top-ports 20 target_ip'?**

Numerical input (Integer)

Final True Answer: 20

Professor's Detailed Explanation:

The Nmap flag ` - top-ports <n>` allows an ethical hacker to specify an exact number n of highest-priority ports to probe, selected from Nmap's frequency-ranked `nmap-services` database. When executing `nmap - top-ports 20 target_ip`, Nmap extracts exactly the 20 most commonly open ports (including ports 80, 22, 23, 21, 443, 25, etc.) and scans those 20 ports. Therefore, the total number of ports scanned is exactly 20.

Question 10 **How many total IP addresses will be scanned when executing the command nmap - sL 10.10.5.100-115?**

Numerical input (Integer)

Final True Answer: 16

Professor's Detailed Explanation:

Let us compute the total IP address scope specified in the target range `10.10.5.100-115`:
1. Nmap's range notation `100-115` in the final octet specifies an inclusive contiguous block of IP addresses starting at `10.10.5.100` and ending at `10.10.5.115`.
2. To find the total count of inclusive integer addresses: Total IPs = Last Address - First Address + 1 = 115 - 100 + 1 = 16 IP addresses.
3. The `-sL` (List Scan) option is a non-intrusive discovery scan that simply enumerates and prints every IP address in the specified range and performs reverse DNS resolution without sending a single packet to the hosts themselves. Thus, Nmap will list and evaluate exactly 16 IP addresses.

Final Examination Preparation & Strategy Recommendations

Congratulations on completing all 13 modules of the NPTEL Ethical Hacking course. As you prepare for the final proctored examination, keep these core principles in mind:

1. Command Syntax and Flags: Pay special attention to exact tool syntax, especially Nmap scan flags (`-sS`, `-sT`, `-sU`, `-sA`, `-sN`, `-sF`, `-sX`), host discovery options (`-sn`, `-Pn`), and target specification ranges.
2. Numerical and Step-by-Step Calculations: Be thoroughly comfortable with network latency formulas (Transmission Delay + Propagation Delay), fragmentation offset computations (multiplying by 8 bytes), subnetting masks, and modular arithmetic in classical ciphers (Caesar, Playfair, Affine, Hill, and Vigenere).
3. Conceptual Precision: Distinguish clearly between related protocols and mechanisms: ARP versus RARP, TCP three-way handshake versus connection teardown, symmetric versus asymmetric cryptography, and stream versus block ciphers.

Review the detailed explanations in this guide multiple times to reinforce both theoretical foundations and practical applications. Best of luck on your examination and your journey in cyber security!